CONFIDENTIAL



SECURITY ASSESSMENT REPORT

Secure Source Code Review

KavachBank

PREPARED FOR	**Thapar Institute of Engineering and Technology**
PREPARED BY	**CodeKavach Security Review**
REPORT ID	**CK-RPT-2026-CZHQY0WJ**
VERSION	**1.0**
ISSUE DATE	**12 November 2026**
OVERALL RISK	**Critical**

Document control

Report identifier	CK-RPT-2026-CZHQY0WJ
Document version	1.0
Issue date	12 November 2026
Classification	**Confidential**. Contains security-sensitive information about the client's systems. Distribute only to the named recipients; do not forward outside the engagement.
Prepared by	CodeKavach Security Review
Prepared for	Thapar Institute of Engineering and Technology
Scan identifier	`scan_01M78VV81Y29KGWQC4CZHQY0WJ`
Configuration digest	`5f925e96e668b31760fca6d0a34d1f7958f413bcc58dcc002f346f80dc8b6f66`

Version history

VERSION	DATE	AUTHOR	CHANGE	STATE
1.0	12 November 2026	CodeKavach Security Review	Report issued from scan scan_01M78VV81Y29KGWQC4CZHQY0WJ	final

Distribution

NAME	ROLE	ORGANISATION
Security lead	Recipient	Thapar Institute of Engineering and Technology
Engineering lead	Recipient	Thapar Institute of Engineering and Technology

Approval

ROLE	NAME	SIGNATURE / DATE
Prepared by	Lead reviewer	
Reviewed by	Quality reviewer	
Approved by	Engagement owner	

This report presents the results of an automated, model-assisted secure source code review of the code version identified in the scope section, at the date of the review. It is not a guarantee that the code is free of further vulnerabilities: automated analysis has known false-negative rates, and findings should be read together with the limitations listed in the appendices. Model-assisted assessments are advisory and are recorded with the model and provider that produced them; no finding was dismissed by a model.

(c) 2026 CodeKavach Security Review. Prepared for Thapar Institute of Engineering and Technology.

Contents

1 Executive summary 5
2 Scope and approach 6
3 Methodology 7
4 Risk rating method 9
5 Summary of findings 10
6 Detailed findings 16
7 Remediation roadmap 116
8 Privacy attestation 119
9 Appendices 121

1 Executive summary

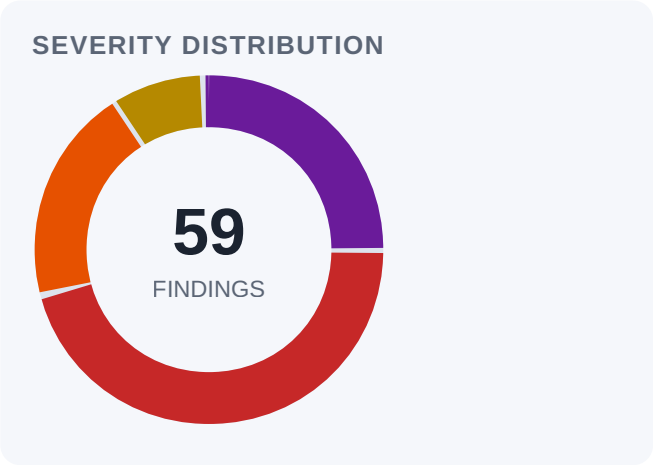
Critical risk

Overall security posture of KavachBank based on 59 findings at privacy level L3.

15	27	12	5	0
CRITICAL	HIGH	MEDIUM	LOW	INFO

Thapar Institute of Engineering and Technology commissioned a secure source code review of KavachBank. The review was performed on 12 November 2026 with CodeKavach, combining deterministic rule and taint analysis with model-assisted triage under a privacy-preserving egress policy. 29 files and 936 lines of YAML, Python, JavaScript, Dockerfile, Terraform code were analysed.

The review identified 59 findings (15 critical, 27 high, 12 medium, 5 low). The overall security posture is rated critical: at least one weakness can be exploited to compromise the application or its data, and immediate action is required. 6 findings are supported by a complete source-to-sink data-flow trace. 12 findings were independently assessed by the language model gpt-5.6-sol (agentrouter); it judged 5 of them exploitable. Model assessments are advisory and no finding was dismissed by a model.



Most significant findings

- CK-2026-001 (Critical): A pull_request_target workflow checks out the pull request head, running untrusted code with repository secrets and a write token. An attacker can run code with the pipeline's secrets and write token, tamper with releases and pivot into the supply chain.
- CK-2026-002 (Critical): Container 'api' is privileged. Any other weakness in the component becomes a full host or cluster compromise, because the attacker inherits the excess privileges.
- CK-2026-003 (Critical): Data from a http_param source reaches a sql sink (cur.execute). If account_id is attacker-controlled, an attacker can alter the SELECT query and potentially cause find_premium_account to return unauthorized database rows; broader effects depend on the database driver and account permissions.
- CK-2026-004 (Critical): Hard-coded credential of type connection_string (masked preview po****** (51 chars), entropy 4.91 bits/char). Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.
- CK-2026-005 (Critical): Hard-coded credential of type aws_access_key (masked preview AK****** (20 chars), entropy 3.68 bits/char). Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

Where the weaknesses concentrate

The most frequent weakness classes are CWE-798 Use of Hard-coded Credentials (11); CWE-250 Execution with Unnecessary Privileges (8); CWE-1395 Dependency on Vulnerable Third-Party Component (8). By OWASP Top 10 category the largest group is A07:2021 Identification and Authentication Failures (12 findings). Recurring classes indicate a missing shared control rather than isolated mistakes, so the recommendations below address the control as well as each instance.

Strategic recommendations

- Immediate (within 7 days): Revoke and rotate the exposed credential immediately, then load it at run time from a secret manager or environment. [CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007 and others]
- Immediate (within 7 days): Upgrade the component to a fixed version, or remove it if it is not needed. [CK-2026-015]
- Short term (within 30 days): Upgrade the component to a fixed version, or remove it if it is not needed. [CK-2026-026, CK-2026-027, CK-2026-038, CK-2026-040 and others]
- Short term (within 30 days): Run the component as a non-root user, drop the privileged flag and grant only the capabilities it needs. [CK-2026-018, CK-2026-019, CK-2026-021, CK-2026-022]
- Medium term (within 90 days): Run the component as a non-root user, drop the privileged flag and grant only the capabilities it needs. [CK-2026-043, CK-2026-044, CK-2026-047]
- Medium term (within 90 days): Encode output for its HTML context (or use a template engine with auto-escaping) and never send raw request data with res.send or equivalent. [CK-2026-051, CK-2026-054]
- Planned (next release cycle): Do not check out untrusted code in privileged workflows; pin third-party actions to a full commit SHA and reduce the token permissions. [CK-2026-058, CK-2026-059]
- Planned (next release cycle): Pin the component to a reviewed version or digest and replace unmaintained components. [CK-2026-055, CK-2026-057]
- Embed the deterministic rules in CI so that the weakness classes found here are blocked at pull-request time, and schedule a retest once the fixes are deployed.

2 Scope and approach

Client	Thapar Institute of Engineering and Technology
Engagement	ENG-CZHQY0WJ: Secure source code review (white-box, automated with model assistance)
Review period	12 November 2026
Target	KavachBank
Languages	YAML, Python, JavaScript, Dockerfile, Terraform
Excluded paths	`.git/**, .codekavach/**, node_modules/**, .venv/**, venv/**, __pycache__/**, dist/**, build/**, target/**, vendor/**`
Files analysed	29 files, 936 lines

Candidates triaged	59 candidates; 12 reviewed by the model

Objectives

- Identify security weaknesses in the source code that could compromise the confidentiality, integrity or availability of the application and its data.
- Rate each weakness by severity, likelihood and impact, and map it to CWE, OWASP and the applicable compliance controls.
- Provide actionable remediation guidance prioritised by risk.
- Demonstrate, through the egress ledger, exactly what code left the client environment during model-assisted review.

Assumptions

- The code reviewed is the version identified by the commit above.
- Configuration and secrets supplied at deployment time are outside the scope.

3 Methodology

The review followed the phases of NIST SP 800-115 and the OWASP Code Review Guide, executed by the CodeKavach pipeline. Deterministic analysis finds candidates; a language model, reached only through a privacy-preserving egress guard, assesses them; every finding is then rated and mapped to recognised taxonomies.

PHASE	STEP	DESCRIPTION
Planning	Scoping and policy	Scope, exclusions and the per-path privacy policy were fixed in the project configuration before the run; the configuration digest is recorded.
Discovery	Code crawl	Files were discovered, their languages detected and parsed with Tree-sitter into syntax trees, symbols and call graphs.
Analysis	Deterministic analysis	Structural security rules, intra- and inter-procedural taint analysis from sources to sinks, and the configured external engines produced candidates; duplicates were merged by fingerprint.
Privacy	Privacy preparation	Each candidate was cut to a minimal code slice, secrets and personal data were redacted and identifiers pseudonymised as the privacy level requires, and the payload re-scanned by an independent egress guard before any model call.
Validation	Model-assisted triage	Sanitised payloads were reviewed by the configured language model with structured output; every request is recorded in a hash-chained egress ledger. The model's answer is advisory: it can lower confidence but never closes a finding.
Rating	Risk rating	Findings were rated by severity, CVSS where available, and on a five by five likelihood and impact matrix, then mapped to CWE, OWASP and compliance clauses.
Reporting	Reporting	Pseudonyms were restored locally, evidence was cut from the original files with secrets masked, and every report format was rendered from one document model with an integrity manifest.

Privacy levels

What leaves the client environment is governed by the privacy level. This review ran at **L3**.

LEVEL	NAME	WHAT IS SENT TO THE MODEL
L0	Air-gapped	Nothing leaves; only local engines or a local model are used.
L1	Redacted	Code with secrets and personal data replaced by typed placeholders.
L2	Pseudonymised	L1 plus identifiers, literals and comments pseudonymised.
L3	**Minimal slice (default)**	**L2 applied to the minimal code slice of each candidate only.**
L4	Facts only	No code: abstract data-flow facts and questions.

Techniques not performed

- Dynamic application security testing (DAST)
- Manual penetration testing
- Infrastructure and cloud configuration review

4 Risk rating method

Severity

SEVERITY	CVSS	MEANING
CRITICAL	9.0 - 10.0	Directly exploitable; compromise of the system or data.
HIGH	7.0 - 8.9	Exploitable with little effort; serious impact.
MEDIUM	4.0 - 6.9	Exploitable under specific conditions; moderate impact.
LOW	0.1 - 3.9	Limited impact or hard to exploit; defence in depth.
INFO	0.0	Observation or hardening opportunity; no direct risk.

CVSS v4.0 base scores are reported as CVSS-B (base metrics only); CVSS v3.1 vectors are given alongside for tools that do not yet read v4.0. Where a finding has no vector it is marked 'not scored' and its severity comes from the rule.

Likelihood and impact

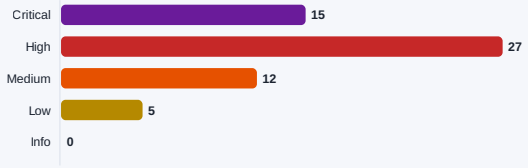
Risk is the product of likelihood and impact on a five-point scale (1 to 25). Products of 20 and above are critical, 12 to 19 high, 6 to 11 medium, 3 to 5 low and below 3 informational.

#	LIKELIHOOD	IMPACT
1	Rare: requires unusual conditions or insider access	Negligible: no data or service affected
2	Unlikely: requires authentication and specific conditions	Minor: limited, non-sensitive data or degraded service
3	Possible: reachable by an authenticated user	Moderate: some sensitive data or a single customer affected
4	Likely: reachable from the network with little effort	Major: sensitive data of many customers or a key function affected
5	Almost certain: reachable anonymously, trivially exploitable	Severe: full system compromise, regulatory breach or financial loss

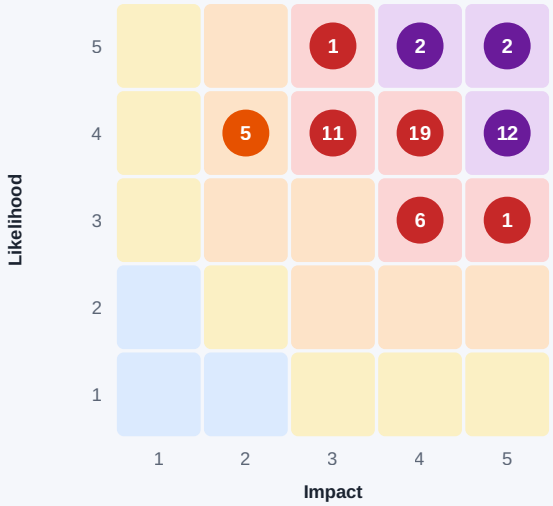
Each finding is mapped to the most specific CWE weakness the rule or engine reports; OWASP Top 10 (2021) categories and compliance clauses are derived from the CWE where the finding does not carry its own mapping, and are marked as derived. Confidence reflects the detection technique (taint path or structural match) and the model's assessment; a model can lower confidence but never dismiss a finding.

5 Summary of findings

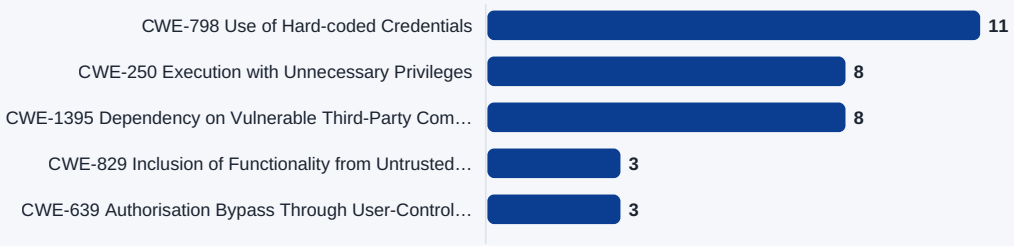
FINDINGS BY SEVERITY



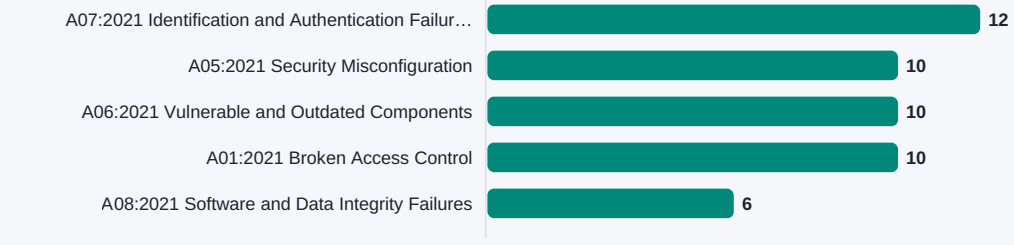
RISK MATRIX (LIKELIHOOD BY IMPACT)



TOP WEAKNESS CLASSES (CWE)



OWASP TOP 10 (2021) CATEGORIES



ID	SEVERITY	TITLE	CWE	LOCATION	RISK	STATUS
CK-2026-001	CRITICAL	A pull_request_target workflow checks out the pull request head, running untrusted code with repository secrets and a write token.	CWE-829	`.github/workflows/ci.yml:12`	20 · critical	**Open**
CK-2026-002	CRITICAL	Container 'api' is privileged.	CWE-250	`deploy/k8s/api.yaml:24`	20 · critical	**Open**

ID	SEVERITY	TITLE	CWE	LOCATION	RISK	STATUS
CK-2026-003	CRITICAL	Data from a http_param source reaches a sql sink (cur.execute)	CWE-89	services/api/accounts.py:11	25 · critical	Open
CK-2026-004	CRITICAL	Hard-coded credential of type connection_string (masked preview po****** (51 chars), entropy 4.91 bits/char).	CWE-798	services/api/config.py:14	20 · critical	Open
CK-2026-005	CRITICAL	Hard-coded credential of type aws_access_key (masked preview AK****** (20 chars), entropy 3.68 bits/char).	CWE-798	services/api/config.py:16	20 · critical	Open
CK-2026-006	CRITICAL	Hard-coded credential of type private_key_block (masked preview --****** (313 chars), entropy 5.97 bits/char).	CWE-798, CWE-321	services/api/config.py:20	20 · critical	Open
CK-2026-007	CRITICAL	Hard-coded credential of type razorpay_key_id (masked preview rz****** (23 chars), entropy 4.26 bits/char).	CWE-798	services/web/config.js:10	20 · critical	Open
CK-2026-008	CRITICAL	Hard-coded credential of type generic_credential (masked preview ad****** (12 chars), entropy 3.08 bits/char).	CWE-798	deploy/docker-compose.yml:9	20 · critical	Open
CK-2026-009	CRITICAL	Hard-coded credential of type aws_secret_key (masked preview wJ****** (40 chars), entropy 4.66 bits/char).	CWE-798	services/api/config.py:17	20 · critical	Open
CK-2026-010	CRITICAL	Hard-coded credential of type razorpay_key_secret (masked preview ab****** (24 chars), entropy 4.58 bits/char).	CWE-798	services/api/config.py:18	20 · critical	Open
CK-2026-011	CRITICAL	Hard-coded credential of type generic_credential (masked preview hu****** (14 chars), entropy 2.81 bits/char).	CWE-798	services/api/config.py:19	20 · critical	Open
CK-2026-012	CRITICAL	A shell command is built from variable parts that are not quoted.	CWE-78	services/api/reports.py:9	25 · critical	Open
CK-2026-013	CRITICAL	Data is deserialised with a loader that can construct arbitrary objects.	CWE-502	services/api/serialisation.py:14	20 · critical	Open
CK-2026-014	CRITICAL	Hard-coded credential of type razorpay_key_secret (masked preview ab****** (24 chars), entropy 4.58 bits/char).	CWE-798	services/web/config.js:11	20 · critical	Open

ID	SEVERITY	TITLE	CWE	LOCATION	RISK	STATUS
CK-2026-015	CRITICAL	Vulnerable dependency: PyYAML 5.3 (CVE-2020-14343)	CWE-1395, CWE-20	services/api/requirements.txt:5	15 · high	Open
CK-2026-016	HIGH	A run step in job 'build' interpolates attacker-controlled event data into a shell script; pass it through an environment variable instead.	CWE-78	.github/workflows/ci.yml:14	20 · critical	Open
CK-2026-017	HIGH	ENV KB_DB_PASSWORD bakes a credential into the image layers; use a build secret or runtime injection.	CWE-798	deploy/Dockerfile:5	16 · high	Open
CK-2026-018	HIGH	Service 'api' runs privileged, giving it nearly full host access.	CWE-250	deploy/docker-compose.yml:4	16 · high	Open
CK-2026-019	HIGH	Service 'api' mounts the Docker socket, which is root on the host.	CWE-250	deploy/docker-compose.yml:6	16 · high	Open
CK-2026-020	HIGH	Service 'api' sets KB_ADMIN_PASSWORD to a literal in the compose file; use an env file or secret store.	CWE-798	deploy/docker-compose.yml:8	16 · high	Open
CK-2026-021	HIGH	Pod shares the host network namespace.	CWE-250	deploy/k8s/api.yaml:15	16 · high	Open
CK-2026-022	HIGH	Pod mounts a hostPath volume, exposing the node filesystem.	CWE-250	deploy/k8s/api.yaml:18	16 · high	Open
CK-2026-023	HIGH	S3 bucket 'statements' uses a public ACL.	CWE-732	infra/main.tf:3	16 · high	Open
CK-2026-024	HIGH	Security group 'admin' allows ingress from the whole internet on an administrative or database port.	CWE-284	infra/main.tf:11	16 · high	Open
CK-2026-025	HIGH	Database 'ledger' is publicly accessible.	CWE-668	infra/main.tf:19	16 · high	Open
CK-2026-026	HIGH	Vulnerable dependency: Flask 2.2.3 (CVE-2023-30861)	CWE-1395, CWE-539	services/api/requirements.txt:2	16 · high	Open
CK-2026-027	HIGH	Vulnerable dependency: requests 2.19.1 (CVE-2018-18074, CVE-2023-32681)	CWE-1395, CWE-522, CWE-200	services/api/requirements.txt:4	16 · high	Open
CK-2026-028	HIGH	TLS certificate verification is disabled, enabling man-in-the-middle attacks.	CWE-295	services/api/settings.yaml:4	16 · high	Open
CK-2026-029	HIGH	A deprecated protocol version (SSLv2/3, TLS 1.0 or 1.1) is allowed.	CWE-326	services/api/settings.yaml:5	16 · high	Open

ID	SEVERITY	TITLE	CWE	LOCATION	RISK	STATUS
CK-2026-030	HIGH	Data from a http_param source reaches a path sink (fs.createReadStream)	CWE-22	services/web/exporter.js:9	20 · critical	**Open**
CK-2026-031	HIGH	Data from a http_param source reaches a http sink (fetch)	CWE-918	services/web/payments.js:18	16 · high	**Open**
CK-2026-032	HIGH	A record is fetched by an identifier from the caller with no ownership check.	CWE-639	services/api/handlers.py:34	16 · high	**Open**
CK-2026-033	HIGH	An account-scoped route has no authentication or authorisation check.	CWE-862	services/api/handlers.py:39	16 · high	**Open**
CK-2026-034	HIGH	A password is hashed with an algorithm that is broken or far too fast.	CWE-327	services/api/security.py:15	16 · high	**Open**
CK-2026-035	HIGH	A block cipher is given a fixed initialisation vector instead of a random one.	CWE-329	services/api/security.py:27	16 · high	**Open**
CK-2026-036	HIGH	Handler takes an object id from the path: worth checking the caller owns it	CWE-639, CWE-863	services/api/handlers.py:39	12 · high	**Open**
CK-2026-037	HIGH	Handler takes an object id from the path: worth checking the caller owns it	CWE-639, CWE-863	services/api/handlers.py:97	12 · high	**Open**
CK-2026-038	HIGH	Vulnerable dependency: Jinja2 2.10 (CVE-2019-10906, CVE-2020-28493, CVE-2024-22195)	CWE-1395, CWE-400, CWE-79	services/api/requirements.txt:3	12 · high	**Open**
CK-2026-039	HIGH	Data from a http_param source reaches a path sink (fs.createReadStream)	CWE-22	services/web/exporter.js:19	16 · high	**Open**
CK-2026-040	HIGH	Vulnerable dependency: lodash 4.17.15 (CVE-2021-23337, CVE-2020-8203, CVE-2020-28500)	CWE-1395, CWE-77, CWE-94, CWE-1321, CWE-1333	services/web/package.json:8	12 · high	**Open**
CK-2026-041	HIGH	Vulnerable dependency: axios 0.21.0 (CVE-2021-3749, CVE-2020-28168)	CWE-1395, CWE-1333, CWE-918	services/web/package.json:9	12 · high	**Open**
CK-2026-042	HIGH	Vulnerable dependency: jsonwebtoken 8.5.1 (CVE-2022-23529)	CWE-1395, CWE-287	services/web/package.json:10	12 · high	**Open**

ID	SEVERITY	TITLE	CWE	LOCATION	RISK	STATUS
CK-2026-043	MEDIUM	The workflow grants write-all permissions to the token.	CWE-250	.github/workflows/ci.yml:5	12 · high	Open
CK-2026-044	MEDIUM	The container runs as root (no non-root USER in the final stage).	CWE-250	deploy/Dockerfile:1	12 · high	Open
CK-2026-045	MEDIUM	ADD fetches a remote URL with no integrity check; use COPY plus a verified download.	CWE-494	deploy/Dockerfile:3	12 · high	Open
CK-2026-046	MEDIUM	Service 'api' shares the host network namespace.	CWE-668	deploy/docker-compose.yml:5	12 · high	Open
CK-2026-047	MEDIUM	Pod security context runs as UID 0.	CWE-250	deploy/k8s/api.yaml:25	12 · high	Open
CK-2026-048	MEDIUM	Database 'ledger' storage is not encrypted.	CWE-311	infra/main.tf:18	12 · high	Open
CK-2026-049	MEDIUM	CORS allows every origin ('*'); any website can call this API from a user's browser.	CWE-942	services/api/settings.yaml:3	12 · high	Open
CK-2026-050	MEDIUM	Vulnerable dependency: express 4.16.0 (CVE-2024-29041, CVE-2024-43796)	CWE-1395, CWE-601, CWE-79	services/web/package.json:7	12 · high	Open
CK-2026-051	MEDIUM	Data from a http_param source reaches a html sink (res.send)	CWE-79	services/web/renderer.js:18	15 · high	Open
CK-2026-052	MEDIUM	RUN pipes a download straight into a shell without integrity verification.	CWE-494	deploy/Dockerfile:4	12 · high	Open
CK-2026-053	MEDIUM	Debug mode is enabled; it exposes stack traces and interactive consoles in production.	CWE-489	services/api/settings.yaml:2	12 · high	Open
CK-2026-054	MEDIUM	Data from a http_param source reaches a html sink (res.send)	CWE-79	services/web/renderer.js:22	12 · high	Open
CK-2026-055	LOW	Base image uses the floating 'latest' tag or no tag, so builds are not reproducible and may pull an unreviewed image.	CWE-1104	deploy/Dockerfile:1	8 · medium	Open
CK-2026-056	LOW	Container 'api' has no resource limits.	CWE-770	deploy/k8s/api.yaml:21	8 · medium	Open
CK-2026-057	LOW	Container 'api' uses a floating image tag.	CWE-1104	deploy/k8s/api.yaml:22	8 · medium	Open
CK-2026-058	LOW	Action reference in job 'build' is not pinned to a commit SHA, so a moved tag changes what runs.	CWE-829	.github/workflows/ci.yml:10	8 · medium	Open

ID	SEVERITY	TITLE	CWE	LOCATION	RISK	STATUS
CK-2026-059	LOW	Action reference in job 'build' is not pinned to a commit SHA, so a moved tag changes what runs.	CWE-829	`.github/workflows/ci.yml:15`	8 · medium	**Open**

6 Detailed findings

CK-2026-001 CRITICAL · Open

A pull_request_target workflow checks out the pull request head, running untrusted code with repository secrets and a write token.

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**4 × 5 = 20 (critical)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**High (likelihood medium, impact high)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
9.3 · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	9.8 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	**CWE-829 Inclusion of Functionality from Untrusted Control Sphere**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A08:2021 Software and Data Integrity Failures	**V10.3.2 · CAPEC-175, CAPEC-201, CAPEC-251**	.github/workflows/ci.yml:12
DETECTED BY		
codekavach-iac:iac.actions.pull-request-target-checkout		

DESCRIPTION

A pull_request_target workflow checks out the pull request head, running untrusted code with repository secrets and a write token. The build or runtime executes code from a source outside the trust boundary, such as an untrusted pull request in a privileged CI workflow or an unpinned third-party action.

EVIDENCE

.github/workflows/ci.yml · lines 12

```
 9      steps:
10        - uses: actions/checkout@v4
11          with:
12            ref: ${{ github.event.pull_request.head.sha }}
13        - name: Greet
14          run: echo "Building ${{ github.event.pull_request.title }}"
15        - uses: some-org/deploy-action@main
```

IMPACT

An attacker can run code with the pipeline's secrets and write token, tamper with releases and pivot into the supply chain.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Separate untrusted builds from privileged jobs and review CI configuration as code.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-829: Inclusion of Functionality from Untrusted Control Sphere https://cwe.mitre.org/data/definitions/829.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Software and Data Integrity Failures https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/CI_CD_Security_Cheat_Sheet.html

Finding find_01M78W6HBTN1BGVXPS9ZV4DJHV · fingerprint ckfp1:8dc24fdf747b5d825f4f94d495f26af1

CK-2026-002 **CRITICAL** · **Open**

Container 'api' is privileged.

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**4 × 5 = 20 (critical)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**Critical (likelihood high, impact high)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
9.3 · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	9.8 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	**CWE-250 Execution with Unnecessary Privileges**

OWASP TOP 10
A05:2021 Security Misconfiguration

ASVS · CAPEC
V14.2.6 · CAPEC-104, CAPEC-470, CAPEC-69

LOCATION
`deploy/k8s/api.yaml:24`

DETECTED BY
`codekavach-iac:iac.k8s.privileged`

DESCRIPTION

Container 'api' is privileged. A process, container or job runs with more privileges than its function requires, for example as root or with a privileged container flag.

EVIDENCE

`deploy/k8s/api.yaml · lines 24`

```
21          - name: api
22            image: kavachbank/api:latest
23            securityContext:
24              privileged: true
25              runAsUser: 0
26            ports:
27              - containerPort: 8000
```

IMPACT

Any other weakness in the component becomes a full host or cluster compromise, because the attacker inherits the excess privileges.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Enforce least privilege with admission policies (for example Pod Security Standards) and image linting in CI.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-250: Execution with Unnecessary Privileges `https://cwe.mitre.org/data/definitions/250.html`
- OWASP Session Management Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html`

- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html

Finding find_01M78W6HD9V5JPYZHSVCBQDR56 · fingerprint ckfp1:d6f2ac50983886921a3b8207cfc82cc7

CK-2026-003 **CRITICAL** · Open

Data from a http_param source reaches a sql sink (cur.execute)

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**5 × 5 = 25 (critical)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**Critical (likelihood high, impact high)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
9.3 · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L/SC:N/SI:N/SA:N	9.4 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L	**CWE-89 SQL Injection** Top 25 #3
OWASP TOP 10	ASVS · CAPEC	LOCATION
A03:2021 Injection	**V5.3.4, V5.3.5 · CAPEC-66, CAPEC-7, CAPEC-108, CAPEC-109, CAPEC-110, CAPEC-470**	services/api/accounts.py:11 in find_premium_account
DETECTED BY		
codekavach-taint:taint.http_param.sql		

DESCRIPTION

Data from a http_param source reaches a sql sink (cur.execute). A database query is built by concatenating or interpolating data that an external party controls, so that data is parsed as SQL rather than treated as a value.

EVIDENCE

services/api/accounts.py · lines 11

```
 8  def find_premium_account(conn, account_id):
 9      """The premium-tier account with this id."""
10      cur = conn.cursor()
11      cur.execute("SELECT * FROM premium_accounts WHERE id = '%s'" % account_id)
12      return cur.fetchone()
13
14
```

DATA FLOW (SOURCE TO SINK)

1 **SOURCE** services/api/handlers.py:97 · premium_account · route parameter account_id

2 **PROPAGATOR** `services/api/handlers.py:99` · premium_account · call find_premium_account arg 1

3 **SINK** `services/api/accounts.py:11` · find_premium_account · cur.execute arg 0

Model assessment: Undecided (medium confidence)

Line 6 is a security-relevant SQL sink: Python percent-formatting embeds account_id into the statement before cursor.execute receives it, so database parameter binding or escaping is not applied. There are no conditional guards between function entry and the sink, making the path satisfiable whenever cursor creation succeeds. Quoting '%s' is not a sanitizer because input containing a quote can change the SQL structure. However, this slice only establishes account_id as a function argument and does not independently prove that an attacker can control it; the rule name alone is insufficient to establish that source.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #1. Advisory: the model cannot close a finding.

IMPACT

If account_id is attacker-controlled, an attacker can alter the SELECT query and potentially cause find_premium_account to return unauthorized database rows; broader effects depend on the database driver and account permissions.

LIKELIHOOD

OWASP likelihood high; confirmed source-to-sink path

REMEDIATION

Fix now

If account_id can be attacker-controlled, use the database driver's parameter-binding API and pass account_id separately from the SQL text, without quoting the placeholder. Optionally enforce the expected identifier type as defense in depth.

Prevent recurrence

Standardise on an ORM or query builder that parameterises by default, restrict the database account to the least privilege required, and add query-construction checks to code review and CI.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.26 | NIST SSDF 1.1 PW.5.1 | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') `https://cwe.mitre.org/data/definitions/89.html`
- OWASP SQL Injection Prevention Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html`
- OWASP Query Parameterization Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Query_Parameterization_Cheat_Sheet.html`
- OWASP Top 10 2021 Injection `https://owasp.org/Top10/A03_2021-Injection/`

Finding find_01M78W6HDTE0E7T3F3PYSEH6C0 · fingerprint ckfp1:f857210f295a9ffb9c2b0792e266d1f5

CK-2026-004 **CRITICAL** · Open

Hard-coded credential of type connection_string (masked preview po****** (51 chars), entropy 4.91 bits/char).

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**4 × 5 = 20 (critical)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
9.1 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	7.4 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N	**CWE-798 Use of Hard-coded Credentials** Top 25 #22
OWASP TOP 10	ASVS · CAPEC	LOCATION
A07:2021 Identification and Authentication Failures	**V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	services/api/config.py:14
DETECTED BY		
codekavach-secrets:secret.connection_string		

DESCRIPTION

Hard-coded credential of type connection_string (masked preview po****** (51 chars), entropy 4.91 bits/char). A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

services/api/config.py · lines 14 · 3 secret values masked

```
11  SESSION_TTL_MINUTES = 30
12  ALLOWED_PARTNER_HOSTS = frozenset({"rates.partner-bank.example", "kyc.partner-bank.example"})
13
14  DATABASE_URL = "<SECRET:connection_string>"
15
16  AWS_ACCESS_KEY_ID = "<SECRET:aws_access_key>"
17  AWS_SECRET_ACCESS_KEY = "<SECRET:aws_secret_key>"
```

IMPACT

Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Remove the credential from source code and version history, rotate it immediately, and load secrets at run time from a secrets manager or the environment. Add secret scanning to the pre-commit hooks and CI so a new secret is caught before it is pushed.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials `https://cwe.mitre.org/data/definitions/798.html`
- OWASP Secrets Management Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html`
- OWASP Top 10 2021 Identification and Authentication Failures `https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/`

`Finding find_01M78W6HE12H37DY994QJPR2SJ · fingerprint ckfp1:ce88bfd661fa6840e71d2ac1b14fe22d`

CK-2026-005 **CRITICAL** · **Open**

Hard-coded credential of type aws_access_key (masked preview AK****** (20 chars), entropy 3.68 bits/char).

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**4 × 5 = 20 (critical)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
9.1 · `CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N`	`7.4 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N`	**CWE-798 Use of Hard-coded Credentials** Top 25 #22

OWASP TOP 10
A07:2021 Identification and Authentication Failures

ASVS · CAPEC
V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70

LOCATION
`services/api/config.py:16`

DETECTED BY
`codekavach-secrets:secret.aws_access_key`

DESCRIPTION

Hard-coded credential of type aws_access_key (masked preview AK****** (20 chars), entropy 3.68 bits/char). A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

`services/api/config.py · lines 16 · 5 secret values masked`

```
13
14  DATABASE_URL = "<SECRET:connection_string>"
15
16  AWS_ACCESS_KEY_ID = "<SECRET:aws_access_key>"
17  AWS_SECRET_ACCESS_KEY = "<SECRET:aws_secret_key>"
18  RAZORPAY_KEY_SECRET = "<SECRET:razorpay_key_secret>"
19  JWT_SIGNING_SECRET = "<SECRET:generic_credential>"
```

IMPACT

Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Remove the credential from source code and version history, rotate it immediately, and load secrets at run time from a secrets manager or the environment. Add secret scanning to the pre-commit hooks and CI so a new secret is caught before it is pushed.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials https://cwe.mitre.org/data/definitions/798.html
- OWASP Secrets Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html
- OWASP Top 10 2021 Identification and Authentication Failures https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/

Finding find_01M78W6HEAQG9RTH3055MYYB7H · fingerprint ckfp1:522ac0d69a6d7101aa18348690cde2ae

CK-2026-006 **CRITICAL** · Open

Hard-coded credential of type private_key_block (masked preview --****** (313 chars), entropy 5.97 bits/char).

SEVERITY **Critical**	RISK (L × I) **4 × 5 = 20 (critical)**	CONFIDENCE **High**
STATUS **Open**	PRIORITY **P1 · Immediate**	OWASP RISK RATING **High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B) **9.1** · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	CVSS V3.1 7.4 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N	CWE **CWE-798 Use of Hard-coded Credentials; CWE-321 Use of Hard-coded Cryptographic Key** **Top 25 #22**
OWASP TOP 10 **A07:2021 Identification and Authentication Failures, A02:2021 Cryptographic Failures**	ASVS · CAPEC **V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	LOCATION services/api/config.py:20-25
DETECTED BY codekavach-secrets:secret.private_key_block		

DESCRIPTION

Hard-coded credential of type private_key_block (masked preview --****** (313 chars), entropy 5.97 bits/char). A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

services/api/config.py · lines 20-25 · 4 secret values masked

```
17  AWS_SECRET_ACCESS_KEY = "<SECRET:aws_secret_key>"
18  RAZORPAY_KEY_SECRET = "<SECRET:razorpay_key_secret>"
19  JWT_SIGNING_SECRET = "<SECRET:generic_credential>"
20  SIGNING_KEY_PEM = """<SECRET:private_key_block>
21
22
23
24
25  """
```

IMPACT

Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Remove the credential from source code and version history, rotate it immediately, and load secrets at run time from a secrets manager or the environment. Add secret scanning to the pre-commit hooks and CI so a new secret is caught before it is pushed.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials https://cwe.mitre.org/data/definitions/798.html
- CWE-321: Use of Hard-coded Cryptographic Key https://cwe.mitre.org/data/definitions/321.html
- OWASP Secrets Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html
- OWASP Top 10 2021 Identification and Authentication Failures https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/
- OWASP Top 10 A02:2021 Cryptographic Failures https://owasp.org/Top10/A02_2021-Cryptographic_Failures/

Finding find_01M78W6HEGNF7AJZ9X7M4SADZ3 · fingerprint ckfp1:0e642beba10d7ce23785220b3d35da4d

CK-2026-007 **CRITICAL** · Open

Hard-coded credential of type razorpay_key_id (masked preview rz****** (23 chars), entropy 4.26 bits/char).

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**4 × 5 = 20 (critical)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
9.1 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	7.4 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N	**CWE-798 Use of Hard-coded Credentials** Top 25 #22
OWASP TOP 10	ASVS · CAPEC	LOCATION
A07:2021 Identification and Authentication Failures	**V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	services/web/config.js:10
DETECTED BY		
codekavach-secrets:secret.razorpay_key_id		

DESCRIPTION

Hard-coded credential of type razorpay_key_id (masked preview rz****** (23 chars), entropy 4.26 bits/char). A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

services/web/config.js · lines 10 · 2 secret values masked

```
 7    exportDir: process.env.KB_EXPORT_DIR || '/var/lib/kavachbank/exports',
 8    allowedHosts: ['rates.partner-bank.example', 'kyc.partner-bank.example'],
 9    sessionTtlMinutes: 30,
10    razorpayKeyId: '<SECRET:razorpay_key_id>',
11    razorpayKeySecret: '<SECRET:razorpay_key_secret>',
12  };
```

Model assessment: Confirmed vulnerable (high confidence)

This is a hardcoded-credential exposure rather than an attacker-input sink. razorpayKeyId contains the hardcoded razorpay key id and razorpayKeySecret contains the corresponding the hardcoded razorpay key secret. Both values are unconditionally placed in module.exports when the module loads, so the path is satisfiable and consumers of the module can access them. No sanitization or indirection protects the credentials; possession of the source or deployed artifact reveals the credential pair.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #30. Advisory: the model cannot close a finding.

IMPACT

Exposure of an active production pair can compromise the associated merchant API identity. An attacker may access payment and customer transaction metadata and perform unauthorized payment operations allowed by the account, potentially causing privacy breaches, fraudulent activity, refunds, or financial loss. If the credentials are test-only, expired, or revoked, the practical impact is substantially reduced. Attack scenario: An attacker gains read access to a source repository, packaged application, container image, backup, or deployed server and extracts `razorpayKeyId` and `razorpayKeySecret`. They then use the pair to authenticate directly to Razorpay, enumerate payment or order records, and invoke authorized operations such as creating payment resources, capturing payments, or issuing refunds, depending on the account's enabled APIs and permissions. Affected: The Razorpay merchant account associated with the embedded credential pair; Payment, order, refund, and related customer transaction data accessible through the Razorpay API; Integrity of payment operations authorized for the account, including captures or refunds where permitted Preconditions: The embedded credentials must still be valid and associated with a usable Razorpay account. The attacker must obtain read access to the source or an artifact containing this module and be able to reach the Razorpay API. Financial and production-data impact additionally requires these to be production rather than test credentials and for the relevant API operations to be enabled.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

1. Revoke and rotate the exposed credential pair immediately. 2. Store the replacement values in the deployment platform's secrets manager; use protected environment variables only if a secrets manager is unavailable. 3. Replace the hardcoded values in razorpayKeyId and razorpayKeySecret with runtime secret lookups. 4. Validate both values at startup and fail closed when either is absent; do not add hardcoded fallback values. 5. Remove the credentials from repository history, build caches, published packages, and deployment artifacts after rotation. 6. Update each deployment environment with its own replacement credentials and verify authentication succeeds. Secure example: ```javascript razorpayKeyId: process.env.razorpayKeyId, razorpayKeySecret: process.env.razorpayKeySecret, ``` Defence in depth: - Enable secret scanning in pre-commit hooks and CI to block future committed credentials. - Use separate, least-privileged credentials for each environment and rotate them periodically. - Prevent configuration objects and environment contents from being exposed through logs, diagnostics, or error responses.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials `https://cwe.mitre.org/data/definitions/798.html`
- OWASP Secrets Management Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html`
- OWASP Top 10 2021 Identification and Authentication Failures `https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/`

`Finding find_01M78W6HGKJVZ4JSWNJ3V58MDD · fingerprint ckfp1:b0e691dd2528ac4125d272a78bcf6445`

CK-2026-008 **CRITICAL** · **Open**

Hard-coded credential of type generic_credential (masked preview ad****** (12 chars), entropy 3.08 bits/char).

SEVERITY **Critical**	RISK (L × I) **4 × 5 = 20 (critical)**	CONFIDENCE **Medium**
STATUS **Open**	PRIORITY **P1 · Immediate**	OWASP RISK RATING **High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B) **9.1** · `CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N`	CVSS V3.1 `7.4 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N`	CWE **CWE-798 Use of Hard-coded Credentials** Top 25 #22
OWASP TOP 10 **A07:2021 Identification and Authentication Failures**	ASVS · CAPEC **V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	LOCATION `deploy/docker-compose.yml:9`
DETECTED BY `codekavach-secrets:secret.generic_credential`		

DESCRIPTION

Hard-coded credential of type generic_credential (masked preview ad****** (12 chars), entropy 3.08 bits/char). A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

deploy/docker-compose.yml · lines 9 · 1 secret value masked

```
6       volumes:
7         - /var/run/docker.sock:/var/run/docker.sock
8       environment:
9         KB_ADMIN_PASSWORD: <SECRET:generic_credential>
10    db:
11      image: postgres:16
12      ports:
```

IMPACT

Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Remove the credential from source code and version history, rotate it immediately, and load secrets at run time from a secrets manager or the environment. Add secret scanning to the pre-commit hooks and CI so a new secret is caught before it is pushed.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials https://cwe.mitre.org/data/definitions/798.html
- OWASP Secrets Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html
- OWASP Top 10 2021 Identification and Authentication Failures https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/

Finding find_01M78W6HCXPAZQ4V9BD3J7DPCM · fingerprint ckfp1:18fc0b275da68bf07f6e4fd1ee21684f

CK-2026-009 **CRITICAL** · Open

Hard-coded credential of type aws_secret_key (masked preview wJ****** (40 chars), entropy 4.66 bits/char).

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**4 × 5 = 20 (critical)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
9.1 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	7.4 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N	**CWE-798 Use of Hard-coded Credentials** Top 25 #22
OWASP TOP 10	ASVS · CAPEC	LOCATION
A07:2021 Identification and Authentication Failures	**V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	services/api/config.py:17
DETECTED BY		
codekavach-secrets:secret.aws_secret_key		

DESCRIPTION

Hard-coded credential of type aws_secret_key (masked preview wJ****** (40 chars), entropy 4.66 bits/char). A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

services/api/config.py · lines 17 · 6 secret values masked

```
14  DATABASE_URL = "<SECRET:connection_string>"
15
16  AWS_ACCESS_KEY_ID = "<SECRET:aws_access_key>"
17  AWS_SECRET_ACCESS_KEY = "<SECRET:aws_secret_key>"
18  RAZORPAY_KEY_SECRET = "<SECRET:razorpay_key_secret>"
19  JWT_SIGNING_SECRET = "<SECRET:generic_credential>"
20  SIGNING_KEY_PEM = """<SECRET:private_key_block>
```

IMPACT

Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Remove the credential from source code and version history, rotate it immediately, and load secrets at run time from a secrets manager or the environment. Add secret scanning to the pre-commit hooks and CI so a new secret is caught before it is pushed.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials `https://cwe.mitre.org/data/definitions/798.html`
- OWASP Secrets Management Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html`
- OWASP Top 10 2021 Identification and Authentication Failures `https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/`

`Finding find_01M78W6HEC3A0FMQ9RRXF4MY0X · fingerprint ckfp1:7ba0b3646c996dfc3ff754e7774f3422`

CK-2026-010 **CRITICAL** · **Open**

Hard-coded credential of type razorpay_key_secret (masked preview ab****** (24 chars), entropy 4.58 bits/char).

SEVERITY **Critical**	RISK (L × I) **4 × 5 = 20 (critical)**	CONFIDENCE **Medium**
STATUS **Open**	PRIORITY **P1 · Immediate**	OWASP RISK RATING **High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B) **9.1** · `CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N`	CVSS V3.1 `7.4 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N`	CWE **CWE-798 Use of Hard-coded Credentials** Top 25 #22
OWASP TOP 10 **A07:2021 Identification and Authentication Failures**	ASVS · CAPEC **V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	LOCATION `services/api/config.py:18`
DETECTED BY `codekavach-secrets:secret.razorpay_key_secret`		

DESCRIPTION

Hard-coded credential of type razorpay_key_secret (masked preview ab****** (24 chars), entropy 4.58 bits/char). A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

services/api/config.py · lines 18 · 5 secret values masked

```
15
16  AWS_ACCESS_KEY_ID = "<SECRET:aws_access_key>"
17  AWS_SECRET_ACCESS_KEY = "<SECRET:aws_secret_key>"
18  RAZORPAY_KEY_SECRET = "<SECRET:razorpay_key_secret>"
19  JWT_SIGNING_SECRET = "<SECRET:generic_credential>"
20  SIGNING_KEY_PEM = """<SECRET:private_key_block>
21
```

IMPACT

Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Remove the credential from source code and version history, rotate it immediately, and load secrets at run time from a secrets manager or the environment. Add secret scanning to the pre-commit hooks and CI so a new secret is caught before it is pushed.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials https://cwe.mitre.org/data/definitions/798.html
- OWASP Secrets Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html
- OWASP Top 10 2021 Identification and Authentication Failures https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/

Finding find_01M78W6HEDX0YQMX6R7BGM5TPH · fingerprint ckfp1:bfc6d200d406cd01e9c432939bbc3e5c

CK-2026-011 **CRITICAL** · Open

Hard-coded credential of type generic_credential (masked preview hu****** (14 chars), entropy 2.81 bits/char).

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**4 × 5 = 20 (critical)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
9.1 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	7.4 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N	**CWE-798 Use of Hard-coded Credentials** Top 25 #22
OWASP TOP 10	ASVS · CAPEC	LOCATION
A07:2021 Identification and Authentication Failures	**V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	services/api/config.py:19
DETECTED BY		
codekavach-secrets:secret.generic_credential		

DESCRIPTION

Hard-coded credential of type generic_credential (masked preview hu****** (14 chars), entropy 2.81 bits/char). A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

services/api/config.py · lines 19 · 5 secret values masked

```
16  AWS_ACCESS_KEY_ID = "<SECRET:aws_access_key>"
17  AWS_SECRET_ACCESS_KEY = "<SECRET:aws_secret_key>"
18  RAZORPAY_KEY_SECRET = "<SECRET:razorpay_key_secret>"
19  JWT_SIGNING_SECRET = "<SECRET:generic_credential>"
20  SIGNING_KEY_PEM = """<SECRET:private_key_block>
21
22
```

IMPACT

Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Remove the credential from source code and version history, rotate it immediately, and load secrets at run time from a secrets manager or the environment. Add secret scanning to the pre-commit hooks and CI so a new secret is caught before it is pushed.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials `https://cwe.mitre.org/data/definitions/798.html`
- OWASP Secrets Management Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html`
- OWASP Top 10 2021 Identification and Authentication Failures `https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/`

`Finding find_01M78W6HEEZ83NWFF9XTPSJ20Q · fingerprint ckfp1:33b2023d79eb4c4e5a1307ac0437b76e`

CK-2026-012 **CRITICAL** · **Open**

A shell command is built from variable parts that are not quoted.

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**5 × 5 = 25 (critical)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**Critical (likelihood high, impact high)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
9.3 · `CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N`	`9.8 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`	**CWE-78 OS Command Injection** **Top 25 #7**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A03:2021 Injection	**V5.3.8 · CAPEC-88, CAPEC-108, CAPEC-15, CAPEC-43**	`services/api/reports.py:9 in archive_statements`
DETECTED BY		
`codekavach.rules:py.command-injection`		

DESCRIPTION

A shell command is built from variable parts that are not quoted. The application builds an operating-system command from data that an external party can influence and runs it through a shell. Shell metacharacters in that data change the command that is executed.

EVIDENCE

services/api/reports.py · lines 9

```
 6
 7  def archive_statements(folder, archive_name):
 8      """Pack a folder of statements into an archive for download."""
 9      subprocess.run(f"zip -r {archive_name} {folder}", shell=True, check=True)
10      return archive_name
11
12
```

Model assessment: Confirmed vulnerable (high confidence)

At line 7, archive_name and folder are interpolated directly into a command string passed to subprocess.run with shell=True. The path from the function parameters to the sink is direct and unconditional, so shell metacharacters supplied in either value can reach the shell. No validation, quoting, or other sink-appropriate sanitization occurs.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #16. Advisory: the model cannot close a finding.

IMPACT

An attacker can execute arbitrary operating-system commands as the application account. This can expose readable data and credentials, modify or delete accessible files, compromise application integrity, and interrupt service. Broader host or connected-system compromise is possible if the process has elevated privileges or valuable credentials. Attack scenario: An attacker supplies a crafted value for `archive_name` containing a command separator followed by an operating-system command. When the application calls `archive_statements`, the shell interprets the injected text as an additional command rather than as a literal `zip` argument. The injected command can then read files, alter application data, or disrupt the host within the process account's permissions. Affected: Files and data accessible to the application process; Application host integrity and availability; Secrets and credentials available to the process Preconditions: An attacker must be able to influence `archive_name` or `folder` and cause `archive_statements` to run. A command shell must be available, as expected by `shell=True`. The resulting access is limited by the operating-system privileges, filesystem access, credentials, and network reachability of the application process.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

1. Replace the formatted command string with an argument list. 2. Remove `shell=True`; `subprocess.run` then invokes the program without shell interpretation. 3. Validate `archive_name` and `folder` against the narrow syntax required by the application, especially to prevent command-line option injection. 4. Keep `check=True` so execution failures are not silently ignored. Secure example: ```python subprocess.run(["zip", "-x", archive_name, folder], check=True) ``` Defence in depth: - Allow-list each parameter according to its expected filename or pattern grammar, including rejecting unexpected option-like values such as those beginning with `-`. - Run the process with minimal filesystem permissions and access only to the required files. - Use a trusted executable path or tightly controlled `PATH`, and consider a timeout to constrain subprocess execution.

Prevent recurrence

Replace shell invocations with native library calls where possible, run the service with least privilege, and add a static-analysis gate that blocks shell=True and string-built commands.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.26 | NIST SSDF 1.1 PW.5.1 | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') https://cwe.mitre.org/data/definitions/78.html
- OWASP OS Command Injection Defense Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/OS_Command_Injection_Defense_Cheat_Sheet.html
- OWASP Injection Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Injection_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Injection https://owasp.org/Top10/A03_2021-Injection/

Finding find_01M78W6HF1C06BNX5CYD12D5FX · fingerprint ckfp1:391253747652ecc07e44b2fa64e9d157

CK-2026-013 **CRITICAL** · **Open**

Data is deserialised with a loader that can construct arbitrary objects.

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**4 × 5 = 20 (critical)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**Critical (likelihood high, impact high)**

CVSS V4.0 (CVSS-B)
9.3 · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

CVSS V3.1
9.8 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE
CWE-502 Deserialisation of Untrusted Data Top 25 #16

OWASP TOP 10
A08:2021 Software and Data Integrity Failures

ASVS · CAPEC
V5.5.1, V5.5.3 · CAPEC-586

LOCATION
services/api/serialisation.py:14 in load_cached_profile

DETECTED BY
codekavach.rules:py.insecure-deserialisation

DESCRIPTION

Data is deserialised with a loader that can construct arbitrary objects. Data from outside the trust boundary is deserialised with a loader that can instantiate arbitrary types or invoke code during loading.

EVIDENCE

services/api/serialisation.py · lines 14

```
11
12  def load_cached_profile(blob):
13      """A customer profile read back from the shared cache."""
14      return pickle.loads(blob)
15
16
17  def load_profile(text):
```

Model assessment: Undecided (high confidence)

pickle.loads at line 7 is a security-relevant deserialization sink because crafted pickle data can invoke attacker-selected callables during loading. The path from blob to the sink is direct and satisfiable for a bytes-like pickle payload, with no sanitizer or integrity check shown. However, the excerpt does not establish whether blob is attacker-influenced or exclusively receives trusted data, so exploitability cannot be decided without the callers of load_cached_profile.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #12. Advisory: the model cannot close a finding.

IMPACT

If an attacker can control blob, a crafted pickle could execute arbitrary Python code with the application's privileges during deserialization.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

If blob can be untrusted, replace pickle with a non-executable format such as JSON plus strict schema validation. If pickle is unavoidable, accept it only from a trusted source and verify a cryptographic signature before calling pickle.loads.

Prevent recurrence

Adopt data-only formats with schema validation at trust boundaries, and sign serialised objects that must round-trip through clients.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.26 | NIST SSDF 1.1 PW.5.1 | SEBI CSCRF 2024 PR.PS | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-502: Deserialization of Untrusted Data `https://cwe.mitre.org/data/definitions/502.html`
- OWASP Deserialization Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Deserialization_Cheat_Sheet.html`
- OWASP Top 10 2021 Software and Data Integrity Failures `https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/`

`Finding find_01M78W6HG467RVYPD6HWV35P8D · fingerprint ckfp1:3d0bd0d24106e265c2408010a236fac2`

CK-2026-014 **CRITICAL** · Open

Hard-coded credential of type razorpay_key_secret (masked preview ab****** (24 chars), entropy 4.58 bits/char).

SEVERITY **Critical**	RISK (L × I) **4 × 5 = 20 (critical)**	CONFIDENCE **Medium**
STATUS **Open**	PRIORITY **P1 · Immediate**	OWASP RISK RATING **High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B) **9.1** · `CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N`	CVSS V3.1 `7.4 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N`	CWE **CWE-798 Use of Hard-coded Credentials** Top 25 #22
OWASP TOP 10 **A07:2021 Identification and Authentication Failures**	ASVS · CAPEC **V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	LOCATION `services/web/config.js:11`
DETECTED BY `codekavach-secrets:secret.razorpay_key_secret`		

DESCRIPTION

Hard-coded credential of type razorpay_key_secret (masked preview ab****** (24 chars), entropy 4.58 bits/char). A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

services/web/config.js · lines 11 · 2 secret values masked

```
 8    allowedHosts: ['rates.partner-bank.example', 'kyc.partner-bank.example'],
 9    sessionTtlMinutes: 30,
10    razorpayKeyId: '<SECRET:razorpay_key_id>',
11    razorpayKeySecret: '<SECRET:razorpay_key_secret>',
12  };
```

Model assessment: Confirmed vulnerable (high confidence)

This is a credential-exposure finding rather than an attacker-input sink: the hardcoded razorpay key secret is embedded directly in the module and exported through `module.exports`. The exposure path is satisfiable whenever the source, package, artifact, or loaded module is accessible. No environment lookup, encryption, redaction, or other effective protection is applied to `razorpayKeySecret`; the environment fallback on line 9 applies only to `exportDir`.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #34. Advisory: the model cannot close a finding.

IMPACT

An attacker can impersonate the application to Razorpay within the credential's permissions. This can expose merchant and transaction data and enable unauthorized changes to payment-related resources, potentially including financially consequential operations. The precise financial impact depends on whether the key is live and which Razorpay APIs it can access. Attack scenario: An attacker obtains a published package, leaked repository, container image, backup, or deployed file containing `services/web/config.js`. They extract `razorpayKeyId` and `razorpayKeySecret`, use the pair to authenticate to Razorpay's API, and then retrieve transaction data or perform payment-related operations such as creating or modifying resources or issuing refunds where the credential's permissions allow it. Affected: The Razorpay merchant API credential pair in `razorpayKeyId` and `razorpayKeySecret`; Payment, order, customer, and transaction data accessible to that credential; Integrity of payment-related resources and financial operations permitted by the credential Preconditions: The attacker must gain read access to the source or an artifact containing this module. The embedded Razorpay credential must still be active, correspond to a usable environment rather than an inert test account, and have permissions for the attempted API operations.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

1. Revoke and rotate the hardcoded razorpay key secret immediately; rotate the associated credential pair if required by the provider. 2. Store the replacement secret in the deployment platform's secrets manager or protected environment configuration. 3. Replace the hard-coded values in `razorpayKeySecret` and `razorpayKeyId` with runtime lookups and provide no literal fallback. 4. Validate required configuration during startup and terminate safely if it is absent. 5. Remove the embedded credentials from repository history, build artifacts, packages, caches, and deployment bundles. 6. Redeploy using the rotated credential and verify that the revoked credential no longer works. Secure example: ```javascript razorpayKeyId: process.env.razorpayKeyId, razorpayKeySecret: process.env.razorpayKeySecret, ``` Defence in depth: - Restrict the runtime identity so it can read only the required secret, and audit secret-access events. - Enable secret scanning in pre-commit hooks and CI to block future credential commits. - Prevent configuration objects and environment variables from being written to logs or error reports.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials https://cwe.mitre.org/data/definitions/798.html
- OWASP Secrets Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html
- OWASP Top 10 2021 Identification and Authentication Failures https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/

Finding find_01M78W6HGSSWY83B0YWBDM6DTZ · fingerprint ckfp1:9385f205a086ca306373f320f3475c6b

CK-2026-015 **CRITICAL** · **Open**

Vulnerable dependency: PyYAML 5.3 (CVE-2020-14343)

SEVERITY	RISK (L × I)	CONFIDENCE
Critical	**3 × 5 = 15 (high)**	**Low**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P1 · Immediate**	**High (likelihood medium, impact high)**

CVSS V4.0 (CVSS-B)
9.3 · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

CVSS V3.1
9.8 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE
CWE-1395 Dependency on Vulnerable Third-Party Component; CWE-20 CWE-20
Top 25

OWASP TOP 10
A06:2021 Vulnerable and Outdated Components, A03:2021 Injection

ASVS · CAPEC
V14.2.1, V5.1.3, V5.1.4 · CAPEC-673

LOCATION
services/api/requirements.txt:5 in PyYAML

DETECTED BY
codekavach-sca:sca.vulnerable-dependency

DESCRIPTION

Vulnerable dependency: PyYAML 5.3 (CVE-2020-14343) - GHSA-8q59-q68h-6hv4 (CVE-2020-14343), critical: PyYAML arbitrary code execution when loading untrusted YAML with the full loader. Fixed in 5.4. Remediation: upgrade PyYAML to 5.4 or later (resolves all listed advisories). Reachability: no import of the package was found in the scanned code; it may be a transitive or unused dependency. Exploitation data: no KEV or EPSS snapshot installed (run `codekavach sca update`).

EVIDENCE

services/api/requirements.txt · lines 5

```
2  Flask==2.2.3
3  Jinja2==2.10
4  requests==2.19.1
5  PyYAML==5.3
6  psycopg2-binary==2.9.5
```

IMPACT

Attackers can exploit the known vulnerability, for which public exploit code is often available, without finding a flaw in the application's own code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Run software composition analysis in CI, keep an SBOM, and automate dependency updates.

Estimated effort: low · target within 7 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27

NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1395: Dependency on Vulnerable Third-Party Component https://cwe.mitre.org/data/definitions/1395.html
- CWE-20: Improper Input Validation https://cwe.mitre.org/data/definitions/20.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html
- OWASP Top 10 A03:2021 Injection https://owasp.org/Top10/A03_2021-Injection/

Finding find_01M78W6HFQ6D22TERZHV14WS7T · fingerprint ckfp1:b85d48f393aa9d6fb0c6845ed970d22b

CK-2026-016 **HIGH** · Open

A run step in job 'build' interpolates attacker-controlled event data into a shell script; pass it through an environment variable instead.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**5 × 4 = 20 (critical)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-78 OS Command Injection** Top 25 #7
OWASP TOP 10	ASVS · CAPEC	LOCATION
A03:2021 Injection	**V5.3.8 · CAPEC-88, CAPEC-108, CAPEC-15, CAPEC-43**	.github/workflows/ci.yml:14
DETECTED BY		
codekavach-iac:iac.actions.script-injection		

DESCRIPTION

A run step in job 'build' interpolates attacker-controlled event data into a shell script; pass it through an environment variable instead. The application builds an operating-system command from data that an external

party can influence and runs it through a shell. Shell metacharacters in that data change the command that is executed.

EVIDENCE

.github/workflows/ci.yml · lines 14

```
11          with:
12            ref: ${{ github.event.pull_request.head.sha }}
13        - name: Greet
14          run: echo "Building ${{ github.event.pull_request.title }}"
15        - uses: some-org/deploy-action@main
```

IMPACT

An attacker can run arbitrary commands with the privileges of the application process, read or alter any data the process can reach, and use the host as a foothold for lateral movement.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Do not build commands, code or templates from untrusted input. Call the program directly with an argument list (for example subprocess.run([...], shell=False)) instead of a shell string, never pass request data to eval/exec or a template compiler, and validate input against a strict allow-list of expected values before it reaches the sink.

Prevent recurrence

Replace shell invocations with native library calls where possible, run the service with least privilege, and add a static-analysis gate that blocks shell=True and string-built commands.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.26 | NIST SSDF 1.1 PW.5.1 | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') https://cwe.mitre.org/data/definitions/78.html
- OWASP OS Command Injection Defense Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/OS_Command_Injection_Defense_Cheat_Sheet.html
- OWASP Injection Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Injection_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Injection https://owasp.org/Top10/A03_2021-Injection/

Finding find_01M78W6HBWFDZ678F1APRRME0W · fingerprint ckfp1:44fc4a7c19d51b3fcb7a297bd23d17bd

CK-2026-017 **HIGH** · **Open**

ENV KB_DB_PASSWORD bakes a credential into the image layers; use a build secret or runtime injection.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**High**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-798 Use of Hard-coded Credentials** Top 25 #22

OWASP TOP 10	ASVS · CAPEC	LOCATION
A07:2021 Identification and Authentication Failures	**V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	deploy/Dockerfile:5

DETECTED BY
codekavach-iac:iac.docker.secret-in-env

DESCRIPTION

ENV KB_DB_PASSWORD bakes a credential into the image layers; use a build secret or runtime injection. A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

deploy/Dockerfile · lines 5 · 1 secret value masked

```
2  WORKDIR /srv/kavachbank
3  ADD https://downloads.kavachbank.example/installer.sh /tmp/installer.sh
4  RUN curl -fsSL https://downloads.kavachbank.example/bootstrap.sh | sh
5  ENV KB_DB_PASSWORD=ch********
6  COPY services/api /srv/kavachbank
7  EXPOSE 8000
8  CMD ["python", "-m", "handlers"]
```

IMPACT

Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Remove the credential from source code and version history, rotate it immediately, and load secrets at run time from a secrets manager or the environment. Add secret scanning to the pre-commit hooks and CI so a new secret is caught before it is pushed.

Prevent recurrence

> Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.
>
> Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials `https://cwe.mitre.org/data/definitions/798.html`
- OWASP Secrets Management Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html`
- OWASP Top 10 2021 Identification and Authentication Failures `https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/`

`Finding find_01M78W6HCEEHFBBRE43N4AVJ8Y · fingerprint ckfp1:adc6c10f9dc51101746f8e554a514787`

CK-2026-018 **HIGH** · **Open**

Service 'api' runs privileged, giving it nearly full host access.

SEVERITY **High**	RISK (L × I) **4 × 4 = 16 (high)**	CONFIDENCE **High**
STATUS **Open**	PRIORITY **P2 · Short term**	OWASP RISK RATING **High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B) **8.3** · `CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N`	CVSS V3.1 `8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N`	CWE **CWE-250 Execution with Unnecessary Privileges**
OWASP TOP 10 **A05:2021 Security Misconfiguration**	ASVS · CAPEC **V14.2.6 · CAPEC-104, CAPEC-470, CAPEC-69**	LOCATION `deploy/docker-compose.yml:4`
DETECTED BY `codekavach-iac:iac.compose.privileged`		

DESCRIPTION

Service 'api' runs privileged, giving it nearly full host access. A process, container or job runs with more privileges than its function requires, for example as root or with a privileged container flag.

EVIDENCE

deploy/docker-compose.yml · lines 4

```
1  services:
2    api:
3      build: .
4      privileged: true
5      network_mode: host
6      volumes:
7        - /var/run/docker.sock:/var/run/docker.sock
```

IMPACT

Any other weakness in the component becomes a full host or cluster compromise, because the attacker inherits the excess privileges.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Enforce least privilege with admission policies (for example Pod Security Standards) and image linting in CI.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-250: Execution with Unnecessary Privileges https://cwe.mitre.org/data/definitions/250.html
- OWASP Session Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html

Finding find_01M78W6HCGZ8S7GWFB4ADH3E06 · fingerprint ckfp1:fbc217c92008eb8e6d8833dd33649b3f

CK-2026-019 **HIGH** · **Open**

Service 'api' mounts the Docker socket, which is root on the host.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**High**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · `CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N`	`8.2` · `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N`	**CWE-250 Execution with Unnecessary Privileges**

OWASP TOP 10	ASVS · CAPEC	LOCATION
A05:2021 Security Misconfiguration	**V14.2.6 · CAPEC-104, CAPEC-470, CAPEC-69**	`deploy/docker-compose.yml:6`

DETECTED BY
`codekavach-iac:iac.compose.docker-socket`

DESCRIPTION

Service 'api' mounts the Docker socket, which is root on the host. A process, container or job runs with more privileges than its function requires, for example as root or with a privileged container flag.

EVIDENCE

`deploy/docker-compose.yml · lines 6 · 1 secret value masked`

```
3     build: .
4     privileged: true
5     network_mode: host
6     volumes:
7       - /var/run/docker.sock:/var/run/docker.sock
8     environment:
9       KB_ADMIN_PASSWORD: <SECRET:generic_credential>
```

IMPACT

Any other weakness in the component becomes a full host or cluster compromise, because the attacker inherits the excess privileges.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Enforce least privilege with admission policies (for example Pod Security Standards) and image linting in CI.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-250: Execution with Unnecessary Privileges https://cwe.mitre.org/data/definitions/250.html
- OWASP Session Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html

Finding find_01M78W6HCTY847KD4SQQFHSM1W · fingerprint ckfp1:52184068ae4ed2f947be1370a08d403a

CK-2026-020 **HIGH** · Open

Service 'api' sets KB_ADMIN_PASSWORD to a literal in the compose file; use an env file or secret store.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-798 Use of Hard-coded Credentials** Top 25 #22
OWASP TOP 10	ASVS · CAPEC	LOCATION
A07:2021 Identification and Authentication Failures	**V2.10.4, V6.4.1 · CAPEC-191, CAPEC-70**	deploy/docker-compose.yml:8
DETECTED BY		
codekavach-iac:iac.compose.secret-in-environment		

DESCRIPTION

Service 'api' sets KB_ADMIN_PASSWORD to a literal in the compose file; use an env file or secret store. A credential such as a password, API key or token is embedded in the source code.

EVIDENCE

deploy/docker-compose.yml · lines 8 · 1 secret value masked

```
5      network_mode: host
6      volumes:
7        - /var/run/docker.sock:/var/run/docker.sock
8      environment:
9        KB_ADMIN_PASSWORD: <SECRET:generic_credential>
10   db:
11     image: postgres:16
```

IMPACT

Anyone with access to the repository, a build artefact or a decompiled binary obtains the credential; rotating it requires a code change and redeployment.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Remove the credential from source code and version history, rotate it immediately, and load secrets at run time from a secrets manager or the environment. Add secret scanning to the pre-commit hooks and CI so a new secret is caught before it is pushed.

Prevent recurrence

Adopt a secret manager, add pre-commit and CI secret scanning, and purge the value from version-control history.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 8.6.2 | ISO/IEC 27001 2022 A.5.17 | ISO/IEC 27001 2022 A.8.4 | NIST SSDF 1.1 PS.1.1 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-798: Use of Hard-coded Credentials https://cwe.mitre.org/data/definitions/798.html
- OWASP Secrets Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html
- OWASP Top 10 2021 Identification and Authentication Failures https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/

Finding find_01M78W6HCV8RKVNV0QAXXYDZTS · fingerprint ckfp1:3c567d478b836d389ecfa443f28ede06

CK-2026-021 **HIGH** · **Open**

Pod shares the host network namespace.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**High**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · `CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N`	`8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N`	**CWE-250 Execution with Unnecessary Privileges**

OWASP TOP 10	ASVS · CAPEC	LOCATION
A05:2021 Security Misconfiguration	**V14.2.6 · CAPEC-104, CAPEC-470, CAPEC-69**	`deploy/k8s/api.yaml:15`

DETECTED BY
`codekavach-iac:iac.k8s.host-network`

DESCRIPTION

Pod shares the host network namespace. A process, container or job runs with more privileges than its function requires, for example as root or with a privileged container flag.

EVIDENCE

`deploy/k8s/api.yaml · lines 15`

```
12        labels:
13          app: kavachbank-api
14      spec:
15        hostNetwork: true
16        volumes:
17          - name: host-logs
18            hostPath:
```

IMPACT

Any other weakness in the component becomes a full host or cluster compromise, because the attacker inherits the excess privileges.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Enforce least privilege with admission policies (for example Pod Security Standards) and image linting in CI.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-250: Execution with Unnecessary Privileges https://cwe.mitre.org/data/definitions/250.html
- OWASP Session Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html

Finding find_01M78W6HCZ55QCAW1AD86QFEBB · fingerprint ckfp1:573a903b88986f34cd7d9f42532dad5d

CK-2026-022 **HIGH** · Open

Pod mounts a hostPath volume, exposing the node filesystem.

SEVERITY **High**	RISK (L × I) **4 × 4 = 16 (high)**	CONFIDENCE **High**
STATUS **Open**	PRIORITY **P2 · Short term**	OWASP RISK RATING **High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B) **8.3** · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	CVSS V3.1 8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	CWE **CWE-250 Execution with Unnecessary Privileges**
OWASP TOP 10 **A05:2021 Security Misconfiguration**	ASVS · CAPEC **V14.2.6 · CAPEC-104, CAPEC-470, CAPEC-69**	LOCATION deploy/k8s/api.yaml:18
DETECTED BY codekavach-iac:iac.k8s.host-path		

DESCRIPTION

Pod mounts a hostPath volume, exposing the node filesystem. A process, container or job runs with more privileges than its function requires, for example as root or with a privileged container flag.

EVIDENCE

deploy/k8s/api.yaml · lines 18

```
15        hostNetwork: true
16        volumes:
17          - name: host-logs
18            hostPath:
19              path: /var/log
20        containers:
21          - name: api
```

IMPACT

Any other weakness in the component becomes a full host or cluster compromise, because the attacker inherits the excess privileges.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Enforce least privilege with admission policies (for example Pod Security Standards) and image linting in CI.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-250: Execution with Unnecessary Privileges https://cwe.mitre.org/data/definitions/250.html
- OWASP Session Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html

Finding find_01M78W6HD5MPAWRSE8FQMSCBT4 · fingerprint ckfp1:2b4f32a3c8e40b14bed5cb0ec46776fc

CK-2026-023 **HIGH** · Open

S3 bucket 'statements' uses a public ACL.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**High**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-732 Incorrect Permission Assignment for Critical Resource**

OWASP TOP 10	ASVS · CAPEC	LOCATION
A01:2021 Broken Access Control	**V4.1.3 · CAPEC-1, CAPEC-17, CAPEC-122, CAPEC-127**	infra/main.tf:3

DETECTED BY
codekavach-iac:iac.terraform.s3-public-acl

DESCRIPTION

S3 bucket 'statements' uses a public ACL. A critical resource is readable or writable by principals that should not have access.

EVIDENCE

infra/main.tf · lines 3

```
1  resource "aws_s3_bucket" "statements" {
2    bucket = "kavachbank-statements"
3    acl    = "public-read"
4  }
5
6  resource "aws_security_group" "admin" {
```

IMPACT

Unauthorised users can read secrets or alter configuration and code.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Enforce authorisation on the server for every request: check that the authenticated principal owns or may act on the referenced object (deny by default), derive the owner from the session rather than from request parameters, and centralise the check in a decorator or policy layer so no handler can skip it.

Prevent recurrence

Audit permissions in CI and use least-privilege defaults.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 7.2.1 | PCI DSS 4.0.1 7.2.2 | ISO/IEC 27001 2022 A.5.15 | ISO/IEC 27001 2022 A.8.3 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-732: Incorrect Permission Assignment for Critical Resource https://cwe.mitre.org/data/definitions/732.html
- OWASP Authorization Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
- OWASP Insecure Direct Object Reference Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Finding find_01M78W6HDDYVD9QGQBFBWCNXMS · fingerprint ckfp1:da2025a06fd3180167cc1156e75f08cc

CK-2026-024 **HIGH** · **Open**

Security group 'admin' allows ingress from the whole internet on an administrative or database port.

SEVERITY **High**	RISK (L × I) **4 × 4 = 16 (high)**	CONFIDENCE **High**
STATUS **Open**	PRIORITY **P2 · Short term**	OWASP RISK RATING **High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B) **8.3** · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	CVSS V3.1 8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	CWE **CWE-284 Improper Access Control**
OWASP TOP 10 **A01:2021 Broken Access Control**	ASVS · CAPEC **V4.1.1 · CAPEC-19**	LOCATION infra/main.tf:11
DETECTED BY codekavach-iac:iac.terraform.open-security-group		

DESCRIPTION

Security group 'admin' allows ingress from the whole internet on an administrative or database port. Access to a resource is not restricted to authorised actors.

EVIDENCE

infra/main.tf · lines 11

```
  8    ingress {
  9      from_port   = 22
 10      to_port     = 22
 11      protocol    = "tcp"
 12      cidr_blocks = ["0.0.0.0/0"]
 13    }
 14  }
```

IMPACT

Unauthorised actors can read or modify protected data or invoke protected functions.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Enforce authorisation on the server for every request: check that the authenticated principal owns or may act on the referenced object (deny by default), derive the owner from the session rather than from request parameters, and centralise the check in a decorator or policy layer so no handler can skip it.

Prevent recurrence

Centralise access control and test it with negative cases.

Estimated effort: medium · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 7.2.1 | PCI DSS 4.0.1 7.2.2 | ISO/IEC 27001 2022 A.5.15 | ISO/IEC 27001 2022 A.8.3 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-284: Improper Access Control https://cwe.mitre.org/data/definitions/284.html
- OWASP Authorization Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
- OWASP Insecure Direct Object Reference Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Finding find_01M78W6HDNHG2JTQ7F37F4078X · fingerprint ckfp1:f5e2e2ef5704cd2a35034c534fe80980

CK-2026-025 **HIGH** · Open

Database 'ledger' is publicly accessible.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-668 Exposure of Resource to Wrong Sphere**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A01:2021 Broken Access Control	**V14.4.1 · CAPEC-1**	infra/main.tf:19
DETECTED BY		
codekavach-iac:iac.terraform.public-database		

DESCRIPTION

Database 'ledger' is publicly accessible. A resource such as a port, bucket or service is exposed beyond its intended audience.

EVIDENCE

infra/main.tf · lines 19

```
16  resource "aws_db_instance" "ledger" {
17    engine              = "postgres"
18    instance_class      = "db.t3.medium"
19    storage_encrypted   = false
20    publicly_accessible = true
21  }
```

IMPACT

Attackers outside the intended sphere can reach and abuse the resource.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Do not write secrets, credentials, tokens or personal data to logs, error messages or URLs. Mask or omit sensitive fields at the logging boundary, return generic error messages to clients, and keep detailed diagnostics server-side.

Prevent recurrence

Define exposure in reviewed infrastructure as code with deny-by-default policies.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 3.5.1 | ISO/IEC 27001 2022 A.8.11 | ISO/IEC 27001 2022 A.8.12 | ISO/IEC 27001 2022 A.5.34 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS | PCI DSS 4.0.1 10.2.1 | PCI DSS 4.0.1 10.3.2 | ISO/IEC 27001 2022 A.8.15 | RBI Cyber Security Framework 2016 Annex 1: Audit logs | SEBI CSCRF 2024 DE.CM | CERT-In 2022 Directions 2022 (iv)

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-668: Exposure of Resource to Wrong Sphere https://cwe.mitre.org/data/definitions/668.html
- OWASP Logging Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html
- OWASP Error Handling Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Error_Handling_Cheat_Sheet.html
- OWASP Top 10 2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Finding find_01M78W6HDR0SC0BFWWMJ6GNM4V · fingerprint ckfp1:a3ba5ded6070685ae6f8ae47062c087a

CK-2026-026 **HIGH** · Open

Vulnerable dependency: Flask 2.2.3 (CVE-2023-30861)

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**High**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**Medium (likelihood medium, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-1395 Dependency on Vulnerable Third-Party Component; CWE-539 CWE-539**

OWASP TOP 10
A06:2021 Vulnerable and Outdated Components, A04:2021 Insecure Design

ASVS · CAPEC
V14.2.1, V3.4.1 · CAPEC-21, CAPEC-31, CAPEC-39

LOCATION
`services/api/requirements.txt:2 in Flask`

DETECTED BY
`codekavach-sca:sca.vulnerable-dependency`

DESCRIPTION

Vulnerable dependency: Flask 2.2.3 (CVE-2023-30861) - GHSA-m2qf-hxjv-5gpq (CVE-2023-30861), high: Flask may cache a response with a session cookie behind a caching proxy. Fixed in 2.2.5, 2.3.2. Remediation: upgrade Flask to 2.2.5 or later (resolves all listed advisories). Reachability: the package is imported (services/api/handlers.py:5); basis: module-level import (the advisory names no symbols). Exploitation data: no KEV or EPSS snapshot installed (run `codekavach sca update`).

EVIDENCE

`services/api/requirements.txt · lines 2`

```
1  # KavachBank API dependencies. Deliberately outdated: several pins carry published advisories.
2  Flask==2.2.3
3  Jinja2==2.10
4  requests==2.19.1
5  PyYAML==5.3
```

IMPACT

Attackers can exploit the known vulnerability, for which public exploit code is often available, without finding a flaw in the application's own code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Run software composition analysis in CI, keep an SBOM, and automate dependency updates.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1395: Dependency on Vulnerable Third-Party Component https://cwe.mitre.org/data/definitions/1395.html
- CWE-539: Use of Persistent Cookies Containing Sensitive Information https://cwe.mitre.org/data/definitions/539.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html
- OWASP Top 10 A04:2021 Insecure Design https://owasp.org/Top10/A04_2021-Insecure_Design/

Finding find_01M78W6HFAQK8HRBVYTFDQSGZG · fingerprint ckfp1:02cd05415aeebbaef4d774ec144b826f

CK-2026-027 **HIGH** · Open

Vulnerable dependency: requests 2.19.1 (CVE-2018-18074, CVE-2023-32681)

SEVERITY **High**	RISK (L × I) **4 × 4 = 16 (high)**	CONFIDENCE **High**
STATUS **Open**	PRIORITY **P2 · Short term**	OWASP RISK RATING **Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B) **8.3** · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	CVSS V3.1 8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	CWE **CWE-1395 Dependency on Vulnerable Third-Party Component; CWE-522 CWE-522; CWE-200 Exposure of Sensitive Information** Top 25
OWASP TOP 10 **A06:2021 Vulnerable and Outdated Components, A04:2021 Insecure Design, A01:2021 Broken Access Control**	ASVS · CAPEC **V14.2.1, V2.4.1, V8.3.1, V8.3.4 · CAPEC-102, CAPEC-50, CAPEC-116, CAPEC-13, CAPEC-169**	LOCATION services/api/requirements.txt:4 in requests
DETECTED BY codekavach-sca:sca.vulnerable-dependency		

DESCRIPTION

Vulnerable dependency: requests 2.19.1 (CVE-2018-18074, CVE-2023-32681) - GHSA-x84v-xcm2-53pg (CVE-2018-18074), high: Requests sends the Authorization header to a different host after a redirect. Fixed in 2.20.0. - GHSA-j8r2-6x86-q33q (CVE-2023-32681), medium: Requests leaks Proxy-Authorization headers to destination servers. Fixed in 2.31.0. Remediation: upgrade requests to 2.31.0 or later (resolves all listed

advisories). Reachability: the package is imported (services/api/webhooks.py:5); basis: module-level import (the advisory names no symbols). Exploitation data: no KEV or EPSS snapshot installed (run `codekavach sca update`).

EVIDENCE

services/api/requirements.txt · lines 4

```
1  # KavachBank API dependencies. Deliberately outdated: several pins carry published advisories.
2  Flask==2.2.3
3  Jinja2==2.10
4  requests==2.19.1
5  PyYAML==5.3
6  psycopg2-binary==2.9.5
```

IMPACT

Attackers can exploit the known vulnerability, for which public exploit code is often available, without finding a flaw in the application's own code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Run software composition analysis in CI, keep an SBOM, and automate dependency updates.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1395: Dependency on Vulnerable Third-Party Component https://cwe.mitre.org/data/definitions/1395.html
- CWE-522: Insufficiently Protected Credentials https://cwe.mitre.org/data/definitions/522.html
- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor https://cwe.mitre.org/data/definitions/200.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/

- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html
- OWASP Top 10 A04:2021 Insecure Design https://owasp.org/Top10/A04_2021-Insecure_Design/
- OWASP Top 10 A01:2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Finding find_01M78W6HFPADJ8J55NTJM97KKR · fingerprint ckfp1:1149473b11ba45fd0f415f0c05f27df2

CK-2026-028 **HIGH** · **Open**

TLS certificate verification is disabled, enabling man-in-the-middle attacks.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-295 Improper Certificate Validation**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A07:2021 Identification and Authentication Failures	**V9.2.1 · CAPEC-459, CAPEC-475**	services/api/settings.yaml:4
DETECTED BY		
codekavach-iac:iac.appconfig.tls-verification-disabled		

DESCRIPTION

TLS certificate verification is disabled, enabling man-in-the-middle attacks. TLS certificate validation is disabled or incomplete.

EVIDENCE

services/api/settings.yaml · lines 4

```
1  # KavachBank API runtime settings (deliberately insecure sample).
2  debug: true
3  cors_allowed_origins: "*"
4  verify_ssl: false
5  min_tls_version: TLSv1.0
```

IMPACT

A network attacker can intercept and modify traffic.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Use current, vetted primitives from a maintained library: AES-GCM or ChaCha20-Poly1305 for encryption with a fresh random nonce per message, SHA-256 or better for integrity, a password hashing function (Argon2id, scrypt, bcrypt) for passwords, and the operating system CSPRNG (Python secrets / os.urandom) for keys, tokens and IVs.

Prevent recurrence

Pin trust stores centrally and forbid verify=False in CI.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-295: Improper Certificate Validation https://cwe.mitre.org/data/definitions/295.html
- OWASP Cryptographic Storage Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html
- OWASP Password Storage Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
- OWASP Top 10 2021 Identification and Authentication Failures https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html

Finding find_01M78W6HGHQ8HM4EEAHEWB7YTX · fingerprint ckfp1:f48b19b6ae26b6afaa8146854453db29

CK-2026-029 **HIGH** · **Open**

A deprecated protocol version (SSLv2/3, TLS 1.0 or 1.1) is allowed.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-326 Inadequate Encryption Strength**

OWASP TOP 10
A02:2021 Cryptographic Failures

ASVS · CAPEC
V6.2.1 · CAPEC-20, CAPEC-112

LOCATION
`services/api/settings.yaml:5`

DETECTED BY
`codekavach-iac:iac.appconfig.weak-tls-version`

DESCRIPTION

A deprecated protocol version (SSLv2/3, TLS 1.0 or 1.1) is allowed. Encryption uses a key size or algorithm strength below current recommendations.

EVIDENCE

`services/api/settings.yaml · lines 5`

```
2  debug: true
3  cors_allowed_origins: "*"
4  verify_ssl: false
5  min_tls_version: TLSv1.0
```

IMPACT

Protected data can be decrypted by an attacker with moderate resources.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Use current, vetted primitives from a maintained library: AES-GCM or ChaCha20-Poly1305 for encryption with a fresh random nonce per message, SHA-256 or better for integrity, a password hashing function (Argon2id, scrypt, bcrypt) for passwords, and the operating system CSPRNG (Python secrets / os.urandom) for keys, tokens and IVs.

Prevent recurrence

Maintain an approved-algorithms list enforced in CI.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-326: Inadequate Encryption Strength `https://cwe.mitre.org/data/definitions/326.html`
- OWASP Cryptographic Storage Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html`

- OWASP Password Storage Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
- OWASP Top 10 2021 Cryptographic Failures https://owasp.org/Top10/A02_2021-Cryptographic_Failures/

Finding find_01M78W6HGJGDMPRNBQKKJXZ7KC · fingerprint ckfp1:8fcccc0180ae0b79338149e8c305c097

CK-2026-030 **HIGH** · Open

Data from a http_param source reaches a path sink (fs.createReadStream)

SEVERITY	RISK (L × I)	CONFIDENCE
High	**5 × 4 = 20 (critical)**	**High**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.7 · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N	7.5 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	**CWE-22 Path Traversal** Top 25 #5

OWASP TOP 10	ASVS · CAPEC	LOCATION
A01:2021 Broken Access Control	**V12.3.1, V12.3.2 · CAPEC-126, CAPEC-64**	services/web/exporter.js:9 in exportStatement

DETECTED BY
codekavach-taint:taint.http_param.path

DESCRIPTION

Data from a http_param source reaches a path sink (fs.createReadStream). A file-system path is built from data an external party controls without checking that the resolved path stays inside the intended directory.

EVIDENCE

services/web/exporter.js · lines 9

```
6
7  function exportStatement(req, res) {
8    const file = path.join(config.exportDir, req.query.file);
9    fs.createReadStream(file).pipe(res);
10 }
11
12 function exportStatementSafely(req, res) {
```

DATA FLOW (SOURCE TO SINK)

1 **SOURCE** services/web/exporter.js:8 · exportStatement · source req.query.file

2 **SINK** services/web/exporter.js:9 · exportStatement · fs.createReadStream arg 0

Model assessment: Confirmed vulnerable (high confidence)

The request-derived req.query.file flows directly into path.join and then to the security-relevant fs.createReadStream sink. The path is unconditional, and an input containing sufficient ../ components can normalize outside config.exportDir. path.join only normalizes the path; it does not validate that the result remains under config.exportDir. No effective allowlist, canonical containment check, or other path-traversal defense is present.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #52. Advisory: the model cannot close a finding.

IMPACT

An attacker can make the application read files outside the intended directory and, where the stream is returned to the requester, obtain any such file readable by the service account. This can disclose application secrets, credentials, source code, or host/container configuration and enable follow-on compromise of associated systems. Attack scenario: An attacker requests the handler with `file` set to a traversal value such as `../../../../etc/passwd` or a path targeting an application configuration file. After query decoding and path normalization, `fs.createReadStream` opens the file outside `config.exportDir`, and the handler streams its contents through `pipe(res)`, potentially revealing credentials or other sensitive data. Affected: Files readable by the server process outside `config.exportDir`, including configuration, source code, credentials, and other sensitive local data; Accounts or downstream services whose credentials are stored in readable files Preconditions: The attacker must be able to invoke `exportStatement` and control `req.query.file`; traversal sequences must reach the handler without effective upstream validation; and the target file must exist and be readable by the server process. Direct disclosure also requires `pipe(res)` to expose the stream to the requester, as is typical for a file-serving response path.

LIKELIHOOD

OWASP likelihood high; entry point network; confirmed source-to-sink path

REMEDIATION

Fix now

Prefer mapping an allowlisted identifier to a server-controlled filename. Otherwise, canonicalize both config.exportDir and the requested file, reject absolute or traversal paths, verify the canonical result remains beneath the canonical base directory, and account for symlink escapes.

Prevent recurrence

Centralise file access behind a storage service that enforces containment, and run the process with a file-system view restricted to the data it needs.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.26 | NIST SSDF 1.1 PW.5.1 | SEBI CSCRF 2024 PR.PS | PCI DSS 4.0.1 7.2.1 | PCI DSS 4.0.1 7.2.2 | ISO/IEC 27001 2022 A.5.15 | ISO/IEC 27001 2022 A.8.3 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') https://cwe.mitre.org/data/definitions/22.html
- OWASP Input Validation Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
- OWASP File Upload Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html
- OWASP Top 10 2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Finding find_01M78W6HGVHKM5XX1AV1DMBQ0X · fingerprint ckfp1:8de48653d65d3e5631c019cbd733ba1b

CK-2026-031 **HIGH** · **Open**

Data from a http_param source reaches a http sink (fetch)

SEVERITY **High**	RISK (L × I) **4 × 4 = 16 (high)**	CONFIDENCE **High**
STATUS **Open**	PRIORITY **P2 · Short term**	OWASP RISK RATING **High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B) **7.8** · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:H/SI:L/SA:N	CVSS V3.1 7.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:N	CWE **CWE-918 Server-Side Request Forgery** **Top 25 #19**
OWASP TOP 10 **A10:2021 Server-Side Request Forgery (SSRF)**	ASVS · CAPEC **V5.2.6, V12.6.1 · CAPEC-664**	LOCATION services/web/payments.js:18 in fetchSettlementStatus
DETECTED BY codekavach-taint:taint.http_param.http		

DESCRIPTION

Data from a http_param source reaches a http sink (fetch). The server issues an outbound request to a URL that the caller chooses, without restricting the destination.

EVIDENCE

services/web/payments.js · lines 18

```
15  }
16
17  async function fetchSettlementStatus(callbackUrl) {
18    const response = await fetch(callbackUrl);
19    return response.json();
20  }
21
```

DATA FLOW (SOURCE TO SINK)

1 **SOURCE** `services/web/routes.js:24` · <callback3> · source req.query.callback

2 **PROPAGATOR** `services/web/routes.js:24` · <callback3> · call fetchSettlementStatus arg 0

3 **SINK** `services/web/payments.js:18` · fetchSettlementStatus · fetch arg 0

Model assessment: Undecided (medium confidence)

fetch uses callbackUrl directly as its request target, so this is a security-relevant SSRF sink if callbackUrl is attacker-controlled and fetchSettlementStatus runs server-side. The path is unconditional and contains no URL validation, allowlist, or other sink-appropriate sanitiser. However, the shown function does not establish the origin of callbackUrl or the execution environment, so exploitability cannot be decided from this slice alone.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #28. Advisory: the model cannot close a finding.

IMPACT

An attacker can make the server reach internal services, cloud metadata endpoints and administrative interfaces that are not exposed to the internet, leading to credential theft and internal reconnaissance.

LIKELIHOOD

OWASP likelihood high; entry point network; confirmed source-to-sink path

REMEDIATION

Fix now

Do not fetch URLs taken from requests. Where the feature needs it, allow-list the scheme, host and port, resolve the host and refuse private, loopback and link-local addresses (including cloud metadata endpoints), disable redirects, and send outbound requests through an egress proxy.

Prevent recurrence

Route outbound calls through an egress proxy with an allow-list, and enforce IMDSv2 or the equivalent metadata protection on cloud hosts.

Estimated effort: medium · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.26 | NIST SSDF 1.1 PW.5.1

SEBI CSCRF 2024 PR.PS | PCI DSS 4.0.1 1.3.2 | ISO/IEC 27001 2022 A.8.20 | RBI Cyber Security Framework 2016 Annex 1: Network security

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-918: Server-Side Request Forgery (SSRF) https://cwe.mitre.org/data/definitions/918.html
- OWASP Server Side Request Forgery Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Server-Side Request Forgery (SSRF) https://owasp.org/Top10/A10_2021-Server-Side_Request_Forgery_%28SSRF%29/
- OWASP Top 10 A10:2021 Server-Side Request Forgery (SSRF) https://owasp.org/Top10/A10_2021-Server-Side_Request_Forgery_(SSRF)/

Finding find_01M78W6HHGHFN4K1T8ZY1R4XF0 · fingerprint ckfp1:7fc708fccd8cf3d7f7f964dbb503e63a

CK-2026-032 **HIGH** · Open

A record is fetched by an identifier from the caller with no ownership check.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.6 · CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	8.1 · CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	**CWE-639 Authorisation Bypass Through User-Controlled Key (IDOR)**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A01:2021 Broken Access Control	**V4.2.1 · CAPEC-1, CAPEC-122**	services/api/handlers.py:34 in account_statement
DETECTED BY		
codekavach.rules:py.insecure-direct-object-reference		

DESCRIPTION

A record is fetched by an identifier from the caller with no ownership check. A record is retrieved by an identifier supplied by the caller without verifying that the caller is entitled to that record.

EVIDENCE

services/api/handlers.py · lines 34

```
31  @require_auth
32  def account_statement(account_id):
33      conn = db.connect()
34      statement = accounts.get_statement(conn, account_id)
35      return jsonify(serialisation.dump_statement(statement))
36
37
```

IMPACT

Any authenticated user can read or change other customers' records by changing the identifier in the request, a direct breach of confidentiality and integrity.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Enforce authorisation on the server for every request: check that the authenticated principal owns or may act on the referenced object (deny by default), derive the owner from the session rather than from request parameters, and centralise the check in a decorator or policy layer so no handler can skip it.

Prevent recurrence

Enforce object-level authorisation in a shared data-access layer and add negative authorisation tests for every resource endpoint.

Estimated effort: medium · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 7.2.1 | PCI DSS 4.0.1 7.2.2 | ISO/IEC 27001 2022 A.5.15 | ISO/IEC 27001 2022 A.8.3 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-639: Authorization Bypass Through User-Controlled Key https://cwe.mitre.org/data/definitions/639.html
- OWASP Authorization Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
- OWASP Insecure Direct Object Reference Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Finding find_01M78W6HEJVNQ5W0B6P4B081Z2 · fingerprint ckfp1:446bf2a3502fa2d5a16e0f251255c726

CK-2026-033 **HIGH** · Open

An account-scoped route has no authentication or authorisation check.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.6 · CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	8.1 · CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	**CWE-862 Missing Authorisation** Top 25 #9
OWASP TOP 10	ASVS · CAPEC	LOCATION
A01:2021 Broken Access Control	**V4.1.1, V4.1.3, V4.2.1 · CAPEC-665**	services/api/handlers.py:39-42 in close_account
DETECTED BY		
codekavach.rules:py.missing-authorization		

DESCRIPTION

An account-scoped route has no authentication or authorisation check. A route that acts on protected resources performs no authentication or authorisation check before doing so.

EVIDENCE

services/api/handlers.py · lines 39-42

```
36
37
38  @app.route("/api/accounts/<account_id>/close", methods=["POST"])
39  def close_account(account_id):
40      conn = db.connect()
41      accounts.close(conn, account_id)
42      return jsonify(status="closed")
43
44
45  @app.route("/api/me/accounts/<account_id>")
```

IMPACT

Unauthenticated or under-privileged callers can invoke the operation directly, bypassing the access-control model.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Enforce authorisation on the server for every request: check that the authenticated principal owns or may act on the referenced object (deny by default), derive the owner from the session rather than from request parameters, and centralise the check in a decorator or policy layer so no handler can skip it.

Prevent recurrence

Make authorisation deny-by-default at the framework level so a new route is protected unless explicitly opened, and test it in CI.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 7.2.1 | PCI DSS 4.0.1 7.2.2 | ISO/IEC 27001 2022 A.5.15 | ISO/IEC 27001 2022 A.8.3 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-862: Missing Authorization `https://cwe.mitre.org/data/definitions/862.html`
- OWASP Authorization Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html`
- OWASP Insecure Direct Object Reference Prevention Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html`
- OWASP Top 10 2021 Broken Access Control `https://owasp.org/Top10/A01_2021-Broken_Access_Control/`

`Finding find_01M78W6HEWZW3G4RHJCQMTMADW · fingerprint ckfp1:2c32cde1bf68653ba18f2c275ece8943`

CK-2026-034 **HIGH** · **Open**

A password is hashed with an algorithm that is broken or far too fast.

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · `CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N`	`6.5 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N`	**CWE-327 Use of a Broken or Risky Cryptographic Algorithm**

OWASP TOP 10
A02:2021 Cryptographic Failures

ASVS · CAPEC
V6.2.2, V6.2.5 · CAPEC-20, CAPEC-97, CAPEC-459, CAPEC-473, CAPEC-475, CAPEC-608

LOCATION
`services/api/security.py:15 in hash_password`

DETECTED BY
`codekavach.rules:py.weak-password-hash`

DESCRIPTION

A password is hashed with an algorithm that is broken or far too fast. The code relies on a cryptographic algorithm that is broken or unsuitable for its purpose, such as MD5 or SHA-1 for password storage.

EVIDENCE

`services/api/security.py · lines 15`

```
12
13  def hash_password(password):
14      """The stored form of a customer password."""
15      return hashlib.md5(password.encode("utf-8")).hexdigest()
16
17
18  def hash_password_strong(password, salt=None):
```

Model assessment: Undecided (high confidence)

At line 7, password flows directly through encode() into hashlib.md5() and the resulting digest is returned. This path is unconditional and therefore satisfiable, and encode() is only a representation conversion—not a sanitizer; there is also no salt or password-specific work factor. However, MD5 is not necessarily security-relevant when used for a non-adversarial checksum or similar non-security purpose. The shown function does not establish that password is a password, that it is attacker-influenced, or that the digest protects authentication or another security property, so exploitability cannot be decided without callers.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #3. Advisory: the model cannot close a finding.

IMPACT

Protected data such as password hashes can be reversed or forged at low cost, exposing customer credentials after any database disclosure.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Use current, vetted primitives from a maintained library: AES-GCM or ChaCha20-Poly1305 for encryption with a fresh random nonce per message, SHA-256 or better for integrity, a password hashing function (Argon2id, scrypt, bcrypt) for passwords, and the operating system CSPRNG (Python secrets / os.urandom) for keys, tokens and IVs.

Prevent recurrence

Maintain an approved-algorithms list, wrap cryptography in a small vetted internal library, and add a CI check that rejects deprecated primitives.

Estimated effort: medium · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-327: Use of a Broken or Risky Cryptographic Algorithm `https://cwe.mitre.org/data/definitions/327.html`
- OWASP Cryptographic Storage Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html`
- OWASP Password Storage Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html`
- OWASP Top 10 2021 Cryptographic Failures `https://owasp.org/Top10/A02_2021-Cryptographic_Failures/`

`Finding find_01M78W6HFS1Z1D1CF5F0Z297X1 · fingerprint ckfp1:6a036d587e50ac65269e6f4ee3cbad58`

CK-2026-035 **HIGH** · **Open**

A block cipher is given a fixed initialisation vector instead of a random one.

SEVERITY **High**	RISK (L × I) **4 × 4 = 16 (high)**	CONFIDENCE **Medium**
STATUS **Open**	PRIORITY **P2 · Short term**	OWASP RISK RATING **Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B) **8.3** · `CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N`	CVSS V3.1 `6.5 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N`	CWE **CWE-329 Predictable Initialisation Vector**
OWASP TOP 10 **A02:2021 Cryptographic Failures**	ASVS · CAPEC **V6.2.6 · CAPEC-20**	LOCATION `services/api/security.py:27 in encrypt_field`
DETECTED BY `codekavach.rules:py.static-iv`		

DESCRIPTION

A block cipher is given a fixed initialisation vector instead of a random one. A block cipher in a chaining mode is used with a fixed or predictable initialisation vector.

EVIDENCE

services/api/security.py · lines 27

```
24
25  def encrypt_field(key, plaintext):
26      """Encrypt a column value before it is stored."""
27      cipher = AES.new(key, AES.MODE_CBC, STATIC_IV)
28      return cipher.encrypt(plaintext.ljust(16 * ((len(plaintext) + 15) // 16)).encode("utf-8"))
29
30
```

Model assessment: Undecided (medium confidence)

AES.new receives STATIC_IV as the CBC IV on line 7, and plaintext is transformed and passed to encrypt on line 8. The path has no branch and is satisfiable for a valid AES key, a valid 16-byte IV, and input that produces block-aligned encoded data. The ljust transformation appears on the plaintext path and does not make a reused or predictable CBC IV safe. However, STATIC_IV is not defined in the supplied code, so it could be a constant/reused value or a freshly generated unpredictable value supplied through mutable external state. The callers are also absent, leaving attacker influence and ciphertext observability unknown. Therefore the reported static-IV weakness cannot be confirmed from this slice.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #6. Advisory: the model cannot close a finding.

IMPACT

If STATIC_IV is reused or predictable and ciphertexts are observable, an attacker may detect repeated plaintext prefixes and learn relationships between encrypted messages.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

If STATIC_IV is reused or predictable, generate a fresh cryptographically random 16-byte IV for every encryption and store or transmit it with the ciphertext; preferably use an authenticated-encryption mode such as AES-GCM with correct nonce uniqueness.

Prevent recurrence

Move to an authenticated encryption mode such as AES-GCM through a vetted library that manages nonces for you.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-329: Generation of Predictable IV with CBC Mode https://cwe.mitre.org/data/definitions/329.html
- OWASP Cryptographic Storage Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html
- OWASP Password Storage Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
- OWASP Top 10 2021 Cryptographic Failures https://owasp.org/Top10/A02_2021-Cryptographic_Failures/

Finding find_01M78W6HG3DWMF60E2MH3196NQ · fingerprint ckfp1:56cd7660b268b5af6f3fbd402ac9e81a

CK-2026-036 **HIGH** · Open

Handler takes an object id from the path: worth checking the caller owns it

SEVERITY	RISK (L × I)	CONFIDENCE
High	**3 × 4 = 12 (high)**	**Low**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.6 · CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	8.1 · CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	**CWE-639 Authorisation Bypass Through User-Controlled Key (IDOR); CWE-863 Incorrect Authorisation** Top 25

OWASP TOP 10	ASVS · CAPEC	LOCATION
A01:2021 Broken Access Control	**V4.2.1, V4.1.3 · CAPEC-1, CAPEC-122**	services/api/handlers.py:39-42 in close_account

DETECTED BY
codekavach-rules:python.authz.object-reference-unscoped

DESCRIPTION

Handler takes an object id from the path: worth checking the caller owns it. A record is retrieved by an identifier supplied by the caller without verifying that the caller is entitled to that record.

EVIDENCE

services/api/handlers.py · lines 39-42

```
36
37
38  @app.route("/api/accounts/<account_id>/close", methods=["POST"])
39  def close_account(account_id):
40      conn = db.connect()
41      accounts.close(conn, account_id)
42      return jsonify(status="closed")
43
44
45  @app.route("/api/me/accounts/<account_id>")
```

IMPACT

Any authenticated user can read or change other customers' records by changing the identifier in the request, a direct breach of confidentiality and integrity.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Enforce authorisation on the server for every request: check that the authenticated principal owns or may act on the referenced object (deny by default), derive the owner from the session rather than from request parameters, and centralise the check in a decorator or policy layer so no handler can skip it.

Prevent recurrence

Enforce object-level authorisation in a shared data-access layer and add negative authorisation tests for every resource endpoint.

Estimated effort: medium · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 7.2.1 | PCI DSS 4.0.1 7.2.2 | ISO/IEC 27001 2022 A.5.15 | ISO/IEC 27001 2022 A.8.3 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-639: Authorization Bypass Through User-Controlled Key https://cwe.mitre.org/data/definitions/639.html
- CWE-863: Incorrect Authorization https://cwe.mitre.org/data/definitions/863.html
- OWASP Authorization Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
- OWASP Insecure Direct Object Reference Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html

- OWASP Top 10 2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Finding find_01M78W6HEY5KWCKG8MBZ58D112 · fingerprint ckfp1:47f68d5285c26da3d2cccef843a52b44

CK-2026-037 **HIGH** · Open

Handler takes an object id from the path: worth checking the caller owns it

SEVERITY	RISK (L × I)	CONFIDENCE
High	**3 × 4 = 12 (high)**	**Low**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.6 · CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	8.1 · CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	**CWE-639 Authorisation Bypass Through User-Controlled Key (IDOR); CWE-863 Incorrect Authorisation** Top 25

OWASP TOP 10	ASVS · CAPEC	LOCATION
A01:2021 Broken Access Control	**V4.2.1, V4.1.3 · CAPEC-1, CAPEC-122**	services/api/handlers.py:97-99 in premium_account

DETECTED BY
codekavach-rules:python.authz.object-reference-unscoped

DESCRIPTION

Handler takes an object id from the path: worth checking the caller owns it. A record is retrieved by an identifier supplied by the caller without verifying that the caller is entitled to that record.

EVIDENCE

services/api/handlers.py · lines 97-99

```
 94
 95  @app.route("/api/premium/<account_id>")
 96  @require_auth
 97  def premium_account(account_id):
 98      conn = db.connect()
 99      return jsonify(accounts.find_premium_account(conn, account_id))
100
101
102  @app.route("/api/statements/archive/legacy", methods=["POST"])
```

IMPACT

Any authenticated user can read or change other customers' records by changing the identifier in the request, a direct breach of confidentiality and integrity.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Enforce authorisation on the server for every request: check that the authenticated principal owns or may act on the referenced object (deny by default), derive the owner from the session rather than from request parameters, and centralise the check in a decorator or policy layer so no handler can skip it.

Prevent recurrence

Enforce object-level authorisation in a shared data-access layer and add negative authorisation tests for every resource endpoint.

Estimated effort: medium · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 7.2.1 | PCI DSS 4.0.1 7.2.2 | ISO/IEC 27001 2022 A.5.15 | ISO/IEC 27001 2022 A.8.3 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-639: Authorization Bypass Through User-Controlled Key https://cwe.mitre.org/data/definitions/639.html
- CWE-863: Incorrect Authorization https://cwe.mitre.org/data/definitions/863.html
- OWASP Authorization Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
- OWASP Insecure Direct Object Reference Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Finding find_01M78W6HF0Z520MP5RKKFND7AG · fingerprint ckfp1:b938aa11544e70ab5a2ba96c10f95908

CK-2026-038 **HIGH** · **Open**

Vulnerable dependency: Jinja2 2.10 (CVE-2019-10906, CVE-2020-28493, CVE-2024-22195)

SEVERITY	RISK (L × I)	CONFIDENCE
High	**3 × 4 = 12 (high)**	**Low**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**Medium (likelihood medium, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-1395 Dependency on Vulnerable Third-Party Component; CWE-400 CWE-400; CWE-79 Cross-site Scripting** Top 25

OWASP TOP 10	ASVS · CAPEC	LOCATION
A06:2021 Vulnerable and Outdated Components, A03:2021 Injection	**V14.2.1, V5.3.3, V5.2.1 · CAPEC-147, CAPEC-227, CAPEC-492, CAPEC-63, CAPEC-588, CAPEC-591, CAPEC-592**	services/api/requirements.txt:3 in Jinja2

DETECTED BY
codekavach-sca:sca.vulnerable-dependency

DESCRIPTION

Vulnerable dependency: Jinja2 2.10 (CVE-2019-10906, CVE-2020-28493, CVE-2024-22195) - GHSA-462w-v97r-4m45 (CVE-2019-10906), high: Jinja2 sandbox escape via str.format_map. Fixed in 2.10.1. - GHSA-g3rq-g295-4j3m (CVE-2020-28493), medium: Jinja2 ReDoS in the urlize filter. Fixed in 2.11.3. - GHSA-h5c8-rqwp-cp95 (CVE-2024-22195), medium: Jinja2 xmlattr filter accepts keys with spaces, enabling XSS. Fixed in 3.1.3. Remediation: upgrade Jinja2 to 3.1.3 or later (resolves all listed advisories). Reachability: no import of the package was found in the scanned code; it may be a transitive or unused dependency. Exploitation data: no KEV or EPSS snapshot installed (run `codekavach sca update`).

EVIDENCE

services/api/requirements.txt · lines 3

```
1  # KavachBank API dependencies. Deliberately outdated: several pins carry published advisories.
2  Flask==2.2.3
3  Jinja2==2.10
4  requests==2.19.1
5  PyYAML==5.3
6  psycopg2-binary==2.9.5
```

IMPACT

Attackers can exploit the known vulnerability, for which public exploit code is often available, without finding a flaw in the application's own code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Run software composition analysis in CI, keep an SBOM, and automate dependency updates.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1395: Dependency on Vulnerable Third-Party Component https://cwe.mitre.org/data/definitions/1395.html
- CWE-400: Uncontrolled Resource Consumption https://cwe.mitre.org/data/definitions/400.html
- CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') https://cwe.mitre.org/data/definitions/79.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html
- OWASP Top 10 A03:2021 Injection https://owasp.org/Top10/A03_2021-Injection/

Finding find_01M78W6HFK0WRFCV3ZYNZH3XME · fingerprint ckfp1:174a6a11b345d9447a5669d2c9433914

CK-2026-039 **HIGH** · **Open**

Data from a http_param source reaches a path sink (fs.createReadStream)

SEVERITY	RISK (L × I)	CONFIDENCE
High	**4 × 4 = 16 (high)**	**Low**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**High (likelihood high, impact medium)**

CVSS V4.0 (CVSS-B)
8.7 · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

CVSS V3.1
7.5 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CWE
CWE-22 Path Traversal
Top 25 #5

OWASP TOP 10
A01:2021 Broken Access Control

ASVS · CAPEC
V12.3.1, V12.3.2 · CAPEC-126, CAPEC-64

LOCATION
services/web/exporter.js:19 in exportStatementSafely

DETECTED BY
codekavach-taint:taint.http_param.path

DESCRIPTION

Data from a http_param source reaches a path sink (fs.createReadStream). A file-system path is built from data an external party controls without checking that the resolved path stays inside the intended directory.

EVIDENCE

services/web/exporter.js · lines 19

```
16      res.status(400).send('unknown statement');
17      return;
18    }
19    fs.createReadStream(resolved).pipe(res);
20  }
21
22  module.exports = { exportStatement, exportStatementSafely };
```

DATA FLOW (SOURCE TO SINK)

1 **SOURCE** services/web/exporter.js:14 · exportStatementSafely · source req.query.file

2 **SINK** services/web/exporter.js:19 · exportStatementSafely · fs.createReadStream arg 0

Model assessment: Assessed not vulnerable (high confidence)

The HTTP-controlled value `req.query.file` reaches the filesystem path used by `fs.createReadStream`, so the sink is security-relevant. However, `path.resolve(root, req.query.file)` normalizes absolute paths and `..` components, and the subsequent separator-aware prefix check permits the sink only when the normalized path is strictly beneath `root`. Attempts to resolve outside the base, including sibling-prefix paths, take the rejecting branch and return. Thus the path to the sink is satisfiable only for contained paths, and the validation is effective against direct path traversal. This check would not prevent traversal through an attacker-controlled symbolic link already beneath `root`, but no ability to create or control such a link is shown.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #26. Advisory: the model cannot close a finding.

IMPACT

An attacker can read or overwrite files outside the intended directory, including configuration files, credentials and other customers' documents.

LIKELIHOOD

OWASP likelihood high; entry point network; confirmed source-to-sink path

REMEDIATION

Fix now

Do not use request data as a file path. Map user input to an identifier in an allow-list, or resolve the joined path (os.path.realpath / Path.resolve) and reject it unless it stays inside the intended base directory; use werkzeug.utils.safe_join or an equivalent helper.

Prevent recurrence

Centralise file access behind a storage service that enforces containment, and run the process with a file-system view restricted to the data it needs.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.26 | NIST SSDF 1.1 PW.5.1 | SEBI CSCRF 2024 PR.PS | PCI DSS 4.0.1 7.2.1 | PCI DSS 4.0.1 7.2.2 | ISO/IEC 27001 2022 A.5.15 | ISO/IEC 27001 2022 A.8.3 | RBI Cyber Security Framework 2016 Annex 1: User access control | SEBI CSCRF 2024 PR.AA

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') https://cwe.mitre.org/data/definitions/22.html
- OWASP Input Validation Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
- OWASP File Upload Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html
- OWASP Top 10 2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Finding find_01M78W6HH2RA50NBJMAVPBFB2S · fingerprint ckfp1:210d827711a2e16419317c0729e63571

CK-2026-040 **HIGH** · **Open**

Vulnerable dependency: lodash 4.17.15 (CVE-2021-23337, CVE-2020-8203, CVE-2020-28500)

SEVERITY	RISK (L × I)	CONFIDENCE
High	**3 × 4 = 12 (high)**	**Low**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**Medium (likelihood medium, impact medium)**

CVSS V4.0 (CVSS-B)
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N

CVSS V3.1
8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

CWE
CWE-1395 Dependency on Vulnerable Third-Party Component; CWE-77 Command Injection; CWE-94 Code Injection; CWE-1321 CWE-1321; CWE-1333
CWE-1333 Top 25

OWASP TOP 10
A06:2021 Vulnerable and Outdated Components, A03:2021 Injection, A08:2021 Software and Data Integrity Failures

ASVS · CAPEC
V14.2.1, V5.3.8, V5.2.4 · CAPEC-15, CAPEC-40, CAPEC-43, CAPEC-75, CAPEC-76, CAPEC-242, CAPEC-35, CAPEC-77, CAPEC-1, CAPEC-180, CAPEC-492

LOCATION
`services/web/package.json:8 in lodash`

DETECTED BY
`codekavach-sca:sca.vulnerable-dependency`

DESCRIPTION

Vulnerable dependency: lodash 4.17.15 (CVE-2021-23337, CVE-2020-8203, CVE-2020-28500) - GHSA-35jh-r3h4-6jhm (CVE-2021-23337), high: Command injection in lodash template. Fixed in 4.17.21. - GHSA-p6mc-m468-83gw (CVE-2020-8203), high: Prototype pollution in lodash zipObjectDeep. Fixed in 4.17.19. - GHSA-29mw-wpgm-hmr9 (CVE-2020-28500), medium: ReDoS in lodash toNumber, trim and trimEnd. Fixed in 4.17.21. Remediation: upgrade lodash to 4.17.21 or later (resolves all listed advisories). Reachability: no import of the package was found in the scanned code; it may be a transitive or unused dependency. Exploitation data: no KEV or EPSS snapshot installed (run `codekavach sca update`).

EVIDENCE

`services/web/package.json · lines 8 · 1 secret value masked`

```
5    "description": "KavachBank web front end (deliberately outdated dependencies)",
6    "dependencies": {
7      "express": "4.16.0",
8      "lodash": "4.17.15",
9      "axios": "0.21.0",
10     "jsonwebtoken": "8.********"
11   }
```

IMPACT

Attackers can exploit the known vulnerability, for which public exploit code is often available, without finding a flaw in the application's own code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Run software composition analysis in CI, keep an SBOM, and automate dependency updates.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1395: Dependency on Vulnerable Third-Party Component https://cwe.mitre.org/data/definitions/1395.html
- CWE-77: Improper Neutralization of Special Elements used in a Command ('Command Injection') https://cwe.mitre.org/data/definitions/77.html
- CWE-94: Improper Control of Generation of Code ('Code Injection') https://cwe.mitre.org/data/definitions/94.html
- CWE-1321: Improperly Controlled Modification of Object Prototype Attributes ('Prototype Pollution') https://cwe.mitre.org/data/definitions/1321.html
- CWE-1333: Inefficient Regular Expression Complexity https://cwe.mitre.org/data/definitions/1333.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html
- OWASP Top 10 A03:2021 Injection https://owasp.org/Top10/A03_2021-Injection/
- OWASP Top 10 A08:2021 Software and Data Integrity Failures https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/

Finding find_01M78W6HHBDCF6VQ0HQQ49E6NG · fingerprint ckfp1:186259c047deb5c6314ee9e48eb10ea8

CK-2026-041 **HIGH** · **Open**

Vulnerable dependency: axios 0.21.0 (CVE-2021-3749, CVE-2020-28168)

SEVERITY	RISK (L × I)	CONFIDENCE
High	**3 × 4 = 12 (high)**	**Low**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**Medium (likelihood medium, impact medium)**

CVSS V4.0 (CVSS-B)
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N

CVSS V3.1
8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

CWE
CWE-1395 Dependency on Vulnerable Third-Party Component; CWE-1333 CWE-1333; CWE-918 Server-Side Request Forgery Top 25

OWASP TOP 10
A06:2021 Vulnerable and Outdated Components, A10:2021 Server-Side Request Forgery (SSRF)

ASVS · CAPEC
V14.2.1, V5.2.6, V12.6.1 · CAPEC-492, CAPEC-664

LOCATION
`services/web/package.json:9 in axios`

DETECTED BY
`codekavach-sca:sca.vulnerable-dependency`

DESCRIPTION

Vulnerable dependency: axios 0.21.0 (CVE-2021-3749, CVE-2020-28168) - GHSA-cph5-m8f7-6c5x (CVE-2021-3749), high: Axios inefficient regular expression complexity. Fixed in 0.21.2. - GHSA-4w2v-q235-vp99 (CVE-2020-28168), medium: Axios server-side request forgery through redirects. Fixed in 0.21.1. Remediation: upgrade axios to 0.21.2 or later (resolves all listed advisories). Reachability: no import of the package was found in the scanned code; it may be a transitive or unused dependency. Exploitation data: no KEV or EPSS snapshot installed (run `codekavach sca update`).

EVIDENCE

`services/web/package.json · lines 9 · 1 secret value masked`

```
6    "dependencies": {
7      "express": "4.16.0",
8      "lodash": "4.17.15",
9      "axios": "0.21.0",
10     "jsonwebtoken": "8.********"
11   }
12 }
```

IMPACT

Attackers can exploit the known vulnerability, for which public exploit code is often available, without finding a flaw in the application's own code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Run software composition analysis in CI, keep an SBOM, and automate dependency updates.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1395: Dependency on Vulnerable Third-Party Component https://cwe.mitre.org/data/definitions/1395.html
- CWE-1333: Inefficient Regular Expression Complexity https://cwe.mitre.org/data/definitions/1333.html
- CWE-918: Server-Side Request Forgery (SSRF) https://cwe.mitre.org/data/definitions/918.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html
- OWASP Top 10 A10:2021 Server-Side Request Forgery (SSRF) https://owasp.org/Top10/A10_2021-Server-Side_Request_Forgery_(SSRF)/

Finding find_01M78W6HHCYFGC7E4V2QSX3YXB · fingerprint ckfp1:ad350edf5d639b5d02c7154c39d4da0b

CK-2026-042 **HIGH** · **Open**

Vulnerable dependency: jsonwebtoken 8.5.1 (CVE-2022-23529)

SEVERITY	RISK (L × I)	CONFIDENCE
High	**3 × 4 = 12 (high)**	**Low**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P2 · Short term**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
8.3 · CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	8.2 · CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	**CWE-1395 Dependency on Vulnerable Third-Party Component; CWE-287 Improper Authentication** Top 25

OWASP TOP 10
A06:2021 Vulnerable and Outdated Components, A07:2021 Identification and Authentication Failures

ASVS · CAPEC
V14.2.1 · CAPEC-114, CAPEC-115, CAPEC-151, CAPEC-194

LOCATION
`services/web/package.json:10 in jsonwebtoken`

DETECTED BY
`codekavach-sca:sca.vulnerable-dependency`

DESCRIPTION

Vulnerable dependency: jsonwebtoken 8.5.1 (CVE-2022-23529) - GHSA-27h2-hvpr-p74q (CVE-2022-23529), high: jsonwebtoken insecure implementation of key retrieval. Fixed in 9.0.0. Remediation: upgrade jsonwebtoken to 9.0.0 or later (resolves all listed advisories). Reachability: no import of the package was found in the scanned code; it may be a transitive or unused dependency. Exploitation data: no KEV or EPSS snapshot installed (run `codekavach sca update`).

EVIDENCE

`services/web/package.json · lines 10 · 1 secret value masked`

```
7      "express": "4.16.0",
8      "lodash": "4.17.15",
9      "axios": "0.21.0",
10     "jsonwebtoken": "8.********"
11   }
12 }
```

IMPACT

Attackers can exploit the known vulnerability, for which public exploit code is often available, without finding a flaw in the application's own code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Run software composition analysis in CI, keep an SBOM, and automate dependency updates.

Estimated effort: low · target within 30 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1395: Dependency on Vulnerable Third-Party Component https://cwe.mitre.org/data/definitions/1395.html
- CWE-287: Improper Authentication https://cwe.mitre.org/data/definitions/287.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html
- OWASP Top 10 A07:2021 Identification and Authentication Failures https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/

Finding find_01M78W6HHE9BEQ81C08MR7QJMY · fingerprint ckfp1:fdffd839b0ff6e99dc32028e0548381e

CK-2026-043 **MEDIUM** · **Open**

The workflow grants write-all permissions to the token.

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**4 × 3 = 12 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
6.3 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N	**CWE-250 Execution with Unnecessary Privileges**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A05:2021 Security Misconfiguration	**V14.2.6 · CAPEC-104, CAPEC-470, CAPEC-69**	.github/workflows/ci.yml:5
DETECTED BY		
codekavach-iac:iac.actions.write-all-permissions		

DESCRIPTION

The workflow grants write-all permissions to the token. A process, container or job runs with more privileges than its function requires, for example as root or with a privileged container flag.

EVIDENCE

.github/workflows/ci.yml · lines 5

```
2  on:
3    pull_request_target:
4      types: [opened, synchronize]
5  permissions: write-all
6  jobs:
7    build:
8      runs-on: ubuntu-latest
```

IMPACT

Any other weakness in the component becomes a full host or cluster compromise, because the attacker inherits the excess privileges.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Enforce least privilege with admission policies (for example Pod Security Standards) and image linting in CI.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-250: Execution with Unnecessary Privileges https://cwe.mitre.org/data/definitions/250.html
- OWASP Session Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html

Finding find_01M78W6HBGVNZ6E0291FMRDR13 · fingerprint ckfp1:d2232406253edaae8e1d5f23a20dabd8

CK-2026-044 **MEDIUM** · Open

The container runs as root (no non-root USER in the final stage).

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**4 × 3 = 12 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
6.3 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N	**CWE-250 Execution with Unnecessary Privileges**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A05:2021 Security Misconfiguration	**V14.2.6 · CAPEC-104, CAPEC-470, CAPEC-69**	deploy/Dockerfile:1
DETECTED BY		
codekavach-iac:iac.docker.root-user		

DESCRIPTION

The container runs as root (no non-root USER in the final stage). A process, container or job runs with more privileges than its function requires, for example as root or with a privileged container flag.

EVIDENCE

deploy/Dockerfile · lines 1

```
1  FROM python:latest
2  WORKDIR /srv/kavachbank
3  ADD https://downloads.kavachbank.example/installer.sh /tmp/installer.sh
4  RUN curl -fsSL https://downloads.kavachbank.example/bootstrap.sh | sh
```

IMPACT

Any other weakness in the component becomes a full host or cluster compromise, because the attacker inherits the excess privileges.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Enforce least privilege with admission policies (for example Pod Security Standards) and image linting in CI.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2

RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-250: Execution with Unnecessary Privileges https://cwe.mitre.org/data/definitions/250.html
- OWASP Session Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html

Finding find_01M78W6HBYDV4JEQDT8QC1WNDG · fingerprint ckfp1:5f995f630df4b6ce444f2ae6584a487a

CK-2026-045 **MEDIUM** · **Open**

ADD fetches a remote URL with no integrity check; use COPY plus a verified download.

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**4 × 3 = 12 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
6.3 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N	**CWE-494 Download of Code Without Integrity Check**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A08:2021 Software and Data Integrity Failures	**V10.3.2 · CAPEC-184, CAPEC-185, CAPEC-186, CAPEC-187**	deploy/Dockerfile:3
DETECTED BY		
codekavach-iac:iac.docker.add-remote-url		

DESCRIPTION

ADD fetches a remote URL with no integrity check; use COPY plus a verified download. Code or binaries are downloaded and executed without verifying a checksum or signature.

EVIDENCE

deploy/Dockerfile · lines 3 · 1 secret value masked

```
1  FROM python:latest
2  WORKDIR /srv/kavachbank
3  ADD https://downloads.kavachbank.example/installer.sh /tmp/installer.sh
4  RUN curl -fsSL https://downloads.kavachbank.example/bootstrap.sh | sh
5  ENV KB_DB_PASSWORD=ch********
6  COPY services/api /srv/kavachbank
```

IMPACT

A network attacker or compromised mirror can substitute malicious code that then runs with build or runtime privileges.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Use signed artefacts and a controlled internal mirror.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-494: Download of Code Without Integrity Check https://cwe.mitre.org/data/definitions/494.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Software and Data Integrity Failures https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/

Finding find_01M78W6HCB0FTFNSQ12AC8GP4E · fingerprint ckfp1:29e05f283efec9654afe01024152b151

CK-2026-046 MEDIUM · Open

Service 'api' shares the host network namespace.

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**4 × 3 = 12 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
6.3 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N	**CWE-668 Exposure of Resource to Wrong Sphere**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A01:2021 Broken Access Control	**V14.4.1 · CAPEC-1**	deploy/docker-compose.yml:5
DETECTED BY		
codekavach-iac:iac.compose.host-network		

DESCRIPTION

Service 'api' shares the host network namespace. A resource such as a port, bucket or service is exposed beyond its intended audience.

EVIDENCE

deploy/docker-compose.yml · lines 5

```
2   api:
3     build: .
4     privileged: true
5     network_mode: host
6     volumes:
7       - /var/run/docker.sock:/var/run/docker.sock
8     environment:
```

IMPACT

Attackers outside the intended sphere can reach and abuse the resource.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Do not write secrets, credentials, tokens or personal data to logs, error messages or URLs. Mask or omit sensitive fields at the logging boundary, return generic error messages to clients, and keep detailed diagnostics server-side.

Prevent recurrence

Define exposure in reviewed infrastructure as code with deny-by-default policies.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 3.5.1 | ISO/IEC 27001 2022 A.8.11 | ISO/IEC 27001 2022 A.8.12 | ISO/IEC 27001 2022 A.5.34 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS | PCI DSS 4.0.1 10.2.1 | PCI DSS 4.0.1 10.3.2 | ISO/IEC 27001 2022 A.8.15 | RBI Cyber Security Framework 2016 Annex 1: Audit logs | SEBI CSCRF 2024 DE.CM | CERT-In 2022 Directions 2022 (iv)

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-668: Exposure of Resource to Wrong Sphere `https://cwe.mitre.org/data/definitions/668.html`
- OWASP Logging Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html`
- OWASP Error Handling Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Error_Handling_Cheat_Sheet.html`
- OWASP Top 10 2021 Broken Access Control `https://owasp.org/Top10/A01_2021-Broken_Access_Control/`

`Finding find_01M78W6HCS9C2GNRQSKYJE7DEV · fingerprint ckfp1:b6206100fa3fd94df2e48e7ea5230286`

CK-2026-047 **MEDIUM** · **Open**

Pod security context runs as UID 0.

SEVERITY **Medium**	RISK (L × I) **4 × 3 = 12 (high)**	CONFIDENCE **High**
STATUS **Open**	PRIORITY **P3 · Medium term**	OWASP RISK RATING **High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B) **6.3** · `CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N`	CVSS V3.1 `4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N`	CWE **CWE-250 Execution with Unnecessary Privileges**
OWASP TOP 10 **A05:2021 Security Misconfiguration**	ASVS · CAPEC **V14.2.6 · CAPEC-104, CAPEC-470, CAPEC-69**	LOCATION `deploy/k8s/api.yaml:25`
DETECTED BY `codekavach-iac:iac.k8s.run-as-root`		

DESCRIPTION

Pod security context runs as UID 0. A process, container or job runs with more privileges than its function requires, for example as root or with a privileged container flag.

EVIDENCE

deploy/k8s/api.yaml · lines 25

```
22            image: kavachbank/api:latest
23            securityContext:
24              privileged: true
25              runAsUser: 0
26            ports:
27              - containerPort: 8000
```

IMPACT

Any other weakness in the component becomes a full host or cluster compromise, because the attacker inherits the excess privileges.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Enforce least privilege with admission policies (for example Pod Security Standards) and image linting in CI.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-250: Execution with Unnecessary Privileges https://cwe.mitre.org/data/definitions/250.html
- OWASP Session Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Docker_Security_Cheat_Sheet.html

Finding find_01M78W6HDB1CR92KTN11EG3SQD · fingerprint ckfp1:091750117ebc2058b0fbe9403e6a824a

CK-2026-048 **MEDIUM** · Open

Database 'ledger' storage is not encrypted.

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**4 × 3 = 12 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
6.3 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N	**CWE-311 Missing Encryption of Sensitive Data**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A04:2021 Insecure Design	**V6.1.1, V8.3.4 · CAPEC-157, CAPEC-37**	infra/main.tf:18
DETECTED BY		
codekavach-iac:iac.terraform.unencrypted-storage		

DESCRIPTION

Database 'ledger' storage is not encrypted. Sensitive data is stored or transmitted without encryption.

EVIDENCE

infra/main.tf · lines 18

```
15
16  resource "aws_db_instance" "ledger" {
17    engine              = "postgres"
18    instance_class      = "db.t3.medium"
19    storage_encrypted   = false
20    publicly_accessible = true
21  }
```

IMPACT

Anyone who can read the storage or the network traffic obtains the data.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Use current, vetted primitives from a maintained library: AES-GCM or ChaCha20-Poly1305 for encryption with a fresh random nonce per message, SHA-256 or better for integrity, a password hashing function (Argon2id, scrypt, bcrypt) for passwords, and the operating system CSPRNG (Python secrets / os.urandom) for keys, tokens and IVs.

Prevent recurrence

Classify data and enforce encryption requirements per class.

Estimated effort: medium · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 3.6.1 | PCI DSS 4.0.1 4.2.1 | ISO/IEC 27001 2022 A.8.24 | NIST SSDF 1.1 PW.5.1 | RBI Cyber Security Framework 2016 Annex 1: Data leak prevention | SEBI CSCRF 2024 PR.DS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-311: Missing Encryption of Sensitive Data https://cwe.mitre.org/data/definitions/311.html
- OWASP Cryptographic Storage Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html
- OWASP Password Storage Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
- OWASP Top 10 2021 Insecure Design https://owasp.org/Top10/A04_2021-Insecure_Design/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html

Finding find_01M78W6HDPHVPXD2M8F2YTHE3Y · fingerprint ckfp1:7782d151cb3c4191c3d20b7a709044fc

CK-2026-049 **MEDIUM** · **Open**

CORS allows every origin ('*'); any website can call this API from a user's browser.

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**4 × 3 = 12 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
6.3 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N	**CWE-942 Permissive Cross-domain Policy**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A05:2021 Security Misconfiguration	**V14.5.3 · CAPEC-111**	services/api/settings.yaml:3
DETECTED BY		
codekavach-iac:iac.appconfig.cors-wildcard		

DESCRIPTION

CORS allows every origin ('*'); any website can call this API from a user's browser. CORS is configured to trust any origin.

EVIDENCE

services/api/settings.yaml · lines 3

```
1  # KavachBank API runtime settings (deliberately insecure sample).
2  debug: true
3  cors_allowed_origins: "*"
4  verify_ssl: false
5  min_tls_version: TLSv1.0
```

IMPACT

Malicious sites can read authenticated responses.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Manage CORS centrally per environment.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-942: Permissive Cross-domain Policy with Untrusted Domains https://cwe.mitre.org/data/definitions/942.html
- OWASP Session Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/

Finding find_01M78W6HGFS6DG23V98F2TWNAK · fingerprint ckfp1:349b16c061dc40d8ca003f9ccc851031

CK-2026-050 **MEDIUM** · **Open**

Vulnerable dependency: express 4.16.0 (CVE-2024-29041, CVE-2024-43796)

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**4 × 3 = 12 (high)**	**High**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**Medium (likelihood medium, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
6.3 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N	**CWE-1395 Dependency on Vulnerable Third-Party Component; CWE-601 Open Redirect; CWE-79 Cross-site Scripting** Top 25

OWASP TOP 10	ASVS · CAPEC	LOCATION
A06:2021 Vulnerable and Outdated Components, A01:2021 Broken Access Control, A03:2021 Injection	**V14.2.1, V5.1.5, V5.3.3, V5.2.1 · CAPEC-178, CAPEC-63, CAPEC-588, CAPEC-591, CAPEC-592**	services/web/package.json:7 in express

DETECTED BY
codekavach-sca:sca.vulnerable-dependency

DESCRIPTION

Vulnerable dependency: express 4.16.0 (CVE-2024-29041, CVE-2024-43796) - GHSA-rv95-896h-c2vc (CVE-2024-29041), medium: Express open redirect in malformed URLs. Fixed in 4.19.2. - GHSA-qw6h-vgh9-j6wx (CVE-2024-43796), low: Express XSS via response.redirect(). Fixed in 4.20.0. Remediation: upgrade express to 4.20.0 or later (resolves all listed advisories). Reachability: the package is imported (services/web/routes.js:3); basis: module-level import (the advisory names no symbols). Exploitation data: no KEV or EPSS snapshot installed (run `codekavach sca update`).

EVIDENCE

services/web/package.json · lines 7 · 1 secret value masked

```
4    "private": true,
5    "description": "KavachBank web front end (deliberately outdated dependencies)",
6    "dependencies": {
7      "express": "4.16.0",
8      "lodash": "4.17.15",
9      "axios": "0.21.0",
10     "jsonwebtoken": "8.********"
```

IMPACT

Attackers can exploit the known vulnerability, for which public exploit code is often available, without finding a flaw in the application's own code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Run software composition analysis in CI, keep an SBOM, and automate dependency updates.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1395: Dependency on Vulnerable Third-Party Component https://cwe.mitre.org/data/definitions/1395.html
- CWE-601: URL Redirection to Untrusted Site ('Open Redirect') https://cwe.mitre.org/data/definitions/601.html
- CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') https://cwe.mitre.org/data/definitions/79.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html
- OWASP Top 10 A01:2021 Broken Access Control https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- OWASP Top 10 A03:2021 Injection https://owasp.org/Top10/A03_2021-Injection/

Finding find_01M78W6HH4XGEHBWWESCNNZSNG · fingerprint ckfp1:45993c81fb9c250d3750cd2e37ed1e05

CK-2026-051 **MEDIUM** · **Open**

Data from a http_param source reaches a html sink (res.send)

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**5 × 3 = 15 (high)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
5.3 · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:P/VC:N/VI:N/VA:N/SC:L/SI:L/SA:N	6.1 · CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N	**CWE-79 Cross-site Scripting** Top 25 #1
OWASP TOP 10	ASVS · CAPEC	LOCATION
A03:2021 Injection	**V5.3.3, V5.2.1 · CAPEC-63, CAPEC-588, CAPEC-591, CAPEC-592**	services/web/renderer.js:18 in renderGreeting
DETECTED BY		
codekavach-taint:taint.http_param.html		

DESCRIPTION

Data from a http_param source reaches a html sink (res.send). Data from the request is written into an HTML response without context-aware output encoding, so a browser may interpret it as markup or script.

EVIDENCE

services/web/renderer.js · lines 18

```
15  }
16
17  function renderGreeting(req, res) {
18    res.send('<h1>Welcome back, ' + req.query.name + '</h1>');
19  }
20
21  function renderGreetingSafely(req, res) {
```

DATA FLOW (SOURCE TO SINK)

1. **SOURCE** services/web/renderer.js:18 · renderGreeting · source req.query.name
2. **SINK** services/web/renderer.js:18 · renderGreeting · res.send arg 0

Model assessment: Confirmed vulnerable (high confidence)

At line 4, attacker-influenced data from req.query.name is concatenated directly into an HTML-shaped string passed to res.send. The sink is security-relevant because send commonly emits a string response as HTML. The path is unconditional once renderGreeting is invoked, and no validation, contextual HTML encoding, or other sanitizer occurs before the value reaches the sink. An attacker can therefore supply markup or script through name and have it interpreted by the browser.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #45. Advisory: the model cannot close a finding.

IMPACT

An attacker can execute JavaScript in another user's browser under the application's origin. This can expose same-origin page data and non-HttpOnly credentials or tokens, alter displayed content, and perform application actions using the victim's authenticated session. The code shown supports reflected rather than persistent exploitation. Attack scenario: An attacker creates a URL whose `name` query value contains markup that breaks out of the surrounding element and executes JavaScript. The attacker sends the URL to an authenticated user. When the user opens it, `renderGreeting` reflects the payload in the HTML response, and the browser executes it under the application's origin, allowing the payload to read same-origin data and issue authenticated requests as the victim. Affected: Browser data accessible to scripts under the application's origin; Authenticated user actions and application data available through the victim's session; Integrity of content displayed to the victim Preconditions: `renderGreeting` must be reachable through an HTTP request; the attacker must control `name`; `res.send` must return the constructed string as browser-rendered HTML; and no downstream sanitizer or effective browser policy such as a restrictive CSP may prevent execution. A victim must load the crafted request.

LIKELIHOOD

OWASP likelihood high; entry point network; confirmed source-to-sink path

REMEDIATION

Fix now

1. Use a maintained HTML-encoding library such as `escape-html`. 2. Convert the query value to a string and encode it immediately before insertion into the HTML response. 3. Keep the encoded value in HTML text content; use the encoder appropriate to the destination if it is later moved into an attribute, URL, script, or style context. 4. If markup is not required, remove the HTML wrapper and explicitly send a `text/plain` response instead. 5. Add regression tests using angle brackets, quotes, entities, and event-handler markup. Secure example: ```javascript res.send('<xx>xxxxxxx xxxx, ' + require('escape-html')(String(req.query.name ?? '')) + '</xx>'); ``` Defence in depth: - Deploy a restrictive Content Security Policy, preferably without `unsafe-inline`, to reduce impact if another injection path exists. - Apply business-specific type and length limits to `req.query.name`; do not treat validation as a substitute for output encoding. - Prefer an auto-escaping server-side template engine for responses containing multiple dynamic HTML values.

Prevent recurrence

Adopt auto-escaping templates throughout, deploy a strict Content-Security-Policy, and set HttpOnly on session cookies.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.26 | NIST SSDF 1.1 PW.5.1 | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') https://cwe.mitre.org/data/definitions/79.html
- OWASP Cross Site Scripting Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Injection https://owasp.org/Top10/A03_2021-Injection/

Finding find_01M78W6HHQFSNH94KD68V4QBHP · fingerprint ckfp1:c61f78565cd3be17d894bac5f10dc4ed

CK-2026-052 **MEDIUM** · Open

RUN pipes a download straight into a shell without integrity verification.

SEVERITY **Medium**	RISK (L × I) **4 × 3 = 12 (high)**	CONFIDENCE **Medium**
STATUS **Open**	PRIORITY **P3 · Medium term**	OWASP RISK RATING **Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B) **6.3** · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	CVSS V3.1 4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N	CWE **CWE-494 Download of Code Without Integrity Check**
OWASP TOP 10 **A08:2021 Software and Data Integrity Failures**	ASVS · CAPEC **V10.3.2 · CAPEC-184, CAPEC-185, CAPEC-186, CAPEC-187**	LOCATION deploy/Dockerfile:4
DETECTED BY codekavach-iac:iac.docker.pipe-to-shell		

DESCRIPTION

RUN pipes a download straight into a shell without integrity verification. Code or binaries are downloaded and executed without verifying a checksum or signature.

EVIDENCE

deploy/Dockerfile · lines 4 · 1 secret value masked

```
1  FROM python:latest
2  WORKDIR /srv/kavachbank
3  ADD https://downloads.kavachbank.example/installer.sh /tmp/installer.sh
4  RUN curl -fsSL https://downloads.kavachbank.example/bootstrap.sh | sh
5  ENV KB_DB_PASSWORD=ch********
6  COPY services/api /srv/kavachbank
7  EXPOSE 8000
```

IMPACT

A network attacker or compromised mirror can substitute malicious code that then runs with build or runtime privileges.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Use signed artefacts and a controlled internal mirror.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-494: Download of Code Without Integrity Check https://cwe.mitre.org/data/definitions/494.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Software and Data Integrity Failures https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/

Finding find_01M78W6HCCQMFHAZ56ZTMMDEGS · fingerprint ckfp1:951844b75af8c872aaa997f4c395566f

CK-2026-053 MEDIUM · Open

Debug mode is enabled; it exposes stack traces and interactive consoles in production.

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**4 × 3 = 12 (high)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**High (likelihood high, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
6.3 · CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	4.8 · CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N	**CWE-489 Active Debug Code**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A05:2021 Security Misconfiguration	**V14.3.2 · CAPEC-121**	services/api/settings.yaml:2
DETECTED BY		
codekavach-iac:iac.appconfig.debug-enabled		

DESCRIPTION

Debug mode is enabled; it exposes stack traces and interactive consoles in production. Debug features or debug mode are left enabled in deployable code.

EVIDENCE

services/api/settings.yaml · lines 2

```
1  # KavachBank API runtime settings (deliberately insecure sample).
2  debug: true
3  cors_allowed_origins: "*"
4  verify_ssl: false
5  min_tls_version: TLSv1.0
```

IMPACT

Debug endpoints and verbose errors disclose internals and can allow code execution.

LIKELIHOOD

OWASP likelihood high; pattern match without a path

REMEDIATION

Fix now

Ship secure defaults: disable debug mode in production, set Secure, HttpOnly and SameSite on session cookies, expire sessions, verify TLS certificates, and restrict CORS to the origins that need it.

Prevent recurrence

Make production configuration the default and check it in CI.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security

SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 2.2.1 | ISO/IEC 27001 2022 A.8.9 | NIST SSDF 1.1 PW.9.1 | RBI Cyber Security Framework 2016 Annex 1: Secure configuration | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-489: Active Debug Code https://cwe.mitre.org/data/definitions/489.html
- OWASP Session Management Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- OWASP Transport Layer Security Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- OWASP Top 10 2021 Security Misconfiguration https://owasp.org/Top10/A05_2021-Security_Misconfiguration/

Finding find_01M78W6HGACGVTSBYKATD9981N · fingerprint ckfp1:e79e90f6f2f8a2e0415cba5705ba4957

CK-2026-054 **MEDIUM** · **Open**

Data from a http_param source reaches a html sink (res.send)

SEVERITY	RISK (L × I)	CONFIDENCE
Medium	**4 × 3 = 12 (high)**	**Low**

STATUS	PRIORITY	OWASP RISK RATING
Open	**P3 · Medium term**	**High (likelihood high, impact medium)**

CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
5.3 · CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:P/VC:N/VI:N/VA:N/SC:L/SI:L/SA:N	6.1 · CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N	**CWE-79 Cross-site Scripting** **Top 25 #1**

OWASP TOP 10	ASVS · CAPEC	LOCATION
A03:2021 Injection	**V5.3.3, V5.2.1 · CAPEC-63, CAPEC-588, CAPEC-591, CAPEC-592**	services/web/renderer.js:22 in renderGreetingSafely

DETECTED BY
codekavach-taint:taint.http_param.html

DESCRIPTION

Data from a http_param source reaches a html sink (res.send). Data from the request is written into an HTML response without context-aware output encoding, so a browser may interpret it as markup or script.

EVIDENCE

services/web/renderer.js · lines 22

```
19  }
20
21  function renderGreetingSafely(req, res) {
22    res.send('<h1>Welcome back, ' + escapeHtml(req.query.name) + '</h1>');
23  }
24
25  module.exports = { escapeHtml, renderTemplate, renderStatementRow, renderGreeting,
renderGreetingSafely };
```

DATA FLOW (SOURCE TO SINK)

1 **SOURCE** `services/web/renderer.js:22` · renderGreetingSafely · source req.query.name

2 **SINK** `services/web/renderer.js:22` · renderGreetingSafely · res.send arg 0

Model assessment: Assessed not vulnerable (high confidence)

The query value req.query.name is attacker-influenced, the path to res.send is unconditional, and the response is an HTML-relevant sink. However, the value is inserted only into element text between fixed tags and is first passed through escapeHtml. HTML escaping is the appropriate contextual encoding for this placement, and no subsequent decoding or unsafe transformation is shown. Therefore, although the tainted-data path is feasible, it is effectively sanitized before reaching the sink.

agentrouter / gpt-5.6-sol · task triage · privacy level L3 · ledger entry #36. Advisory: the model cannot close a finding.

IMPACT

An attacker can execute script in a victim's browser session, steal session tokens, perform actions as the victim and deface or phish from a trusted origin.

LIKELIHOOD

OWASP likelihood high; entry point network; confirmed source-to-sink path

REMEDIATION

Fix now

Encode untrusted data for the output context (HTML body, attribute, JavaScript, URL) using the template engine's auto-escaping, and never mark request data as safe (Markup, |safe, dangerouslySetInnerHTML, innerHTML). Add a restrictive Content-Security-Policy as defence in depth.

Prevent recurrence

Adopt auto-escaping templates throughout, deploy a strict Content-Security-Policy, and set HttpOnly on session cookies.

Estimated effort: low · target within 90 days

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.26 | NIST SSDF 1.1 PW.5.1 | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') https://cwe.mitre.org/data/definitions/79.html
- OWASP Cross Site Scripting Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Injection https://owasp.org/Top10/A03_2021-Injection/

Finding find_01M78W6HHZWCP8RZCRBM733F22 · fingerprint ckfp1:3117800ddb64c87c0a0b6cb7c5e8ef2b

CK-2026-055 LOW · Open

Base image uses the floating 'latest' tag or no tag, so builds are not reproducible and may pull an unreviewed image.

SEVERITY	RISK (L × I)	CONFIDENCE
Low	**4 × 2 = 8 (medium)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P4 · Planned**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
2.0 · CVSS:4.0/AV:L/AC:L/AT:P/PR:L/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L	1.9 · CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N	**CWE-1104 Use of Unmaintained Third-Party Components**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A06:2021 Vulnerable and Outdated Components	**V14.2.1 · CAPEC-538**	deploy/Dockerfile:1
DETECTED BY		
codekavach-iac:iac.docker.unpinned-base-image		

DESCRIPTION

Base image uses the floating 'latest' tag or no tag, so builds are not reproducible and may pull an unreviewed image. A component is unpinned or no longer maintained, so fixes may never arrive and the version that is built can change without review.

EVIDENCE

deploy/Dockerfile · lines 1

```
1  FROM python:latest
2  WORKDIR /srv/kavachbank
3  ADD https://downloads.kavachbank.example/installer.sh /tmp/installer.sh
4  RUN curl -fsSL https://downloads.kavachbank.example/bootstrap.sh | sh
```

IMPACT

A compromised or abandoned upstream can introduce vulnerable or malicious code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Maintain an approved-components list and monitor upstream health.

Estimated effort: low · target next release cycle

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1104: Use of Unmaintained Third Party Components https://cwe.mitre.org/data/definitions/1104.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html

Finding find_01M78W6HC9F1MSZA0A6RMP0EM9 · fingerprint ckfp1:575e0f3b89fa8f08ae6b8a716f3670ab

CK-2026-056 **LOW** · **Open**

Container 'api' has no resource limits.

SEVERITY	RISK (L × I)	CONFIDENCE
Low	**4 × 2 = 8 (medium)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P4 · Planned**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
2.0 · CVSS:4.0/AV:L/AC:L/AT:P/PR:L/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L	1.9 · CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N	**CWE-770 Allocation of Resources Without Limits**

OWASP TOP 10
A04:2021 Insecure Design

ASVS · CAPEC
V11.1.4 · CAPEC-125, CAPEC-130, CAPEC-147

LOCATION
`deploy/k8s/api.yaml:21`

DETECTED BY
`codekavach-iac:iac.k8s.no-limits`

DESCRIPTION

Container 'api' has no resource limits. A resource such as memory, connections or request size is allocated without a limit.

EVIDENCE

`deploy/k8s/api.yaml · lines 21`

```
18            hostPath:
19              path: /var/log
20        containers:
21          - name: api
22            image: kavachbank/api:latest
23            securityContext:
24              privileged: true
```

IMPACT

An attacker can exhaust the resource and deny service to legitimate users.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bound every resource an attacker can drive: limit request and upload sizes, decompressed archive sizes and entry counts, use regular expressions without nested quantifiers (or a linear-time engine) on untrusted input, and set time-outs and rate limits.

Prevent recurrence

Adopt rate limiting and resource quotas as platform defaults.

Estimated effort: low · target next release cycle

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.2.4 | ISO/IEC 27001 2022 A.8.6 | NIST SSDF 1.1 PW.5.1 | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-770: Allocation of Resources Without Limits or Throttling `https://cwe.mitre.org/data/definitions/770.html`
- OWASP Denial of Service Cheat Sheet `https://cheatsheetseries.owasp.org/cheatsheets/Denial_of_Service_Cheat_Sheet.html`

Finding find_01M78W6HD70JP56TYXXQM3B3TY · fingerprint ckfp1:e960c94201a74f9a7e68d1b6a7be8353

CK-2026-057 LOW · Open

Container 'api' uses a floating image tag.

SEVERITY	RISK (L × I)	CONFIDENCE
Low	**4 × 2 = 8 (medium)**	**High**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P4 · Planned**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
2.0 · CVSS:4.0/AV:L/AC:L/AT:P/PR:L/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L	1.9 · CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N	**CWE-1104 Use of Unmaintained Third-Party Components**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A06:2021 Vulnerable and Outdated Components	**V14.2.1 · CAPEC-538**	deploy/k8s/api.yaml:22
DETECTED BY		
codekavach-iac:iac.k8s.latest-image		

DESCRIPTION

Container 'api' uses a floating image tag. A component is unpinned or no longer maintained, so fixes may never arrive and the version that is built can change without review.

EVIDENCE

deploy/k8s/api.yaml · lines 22

```
19              path: /var/log
20        containers:
21          - name: api
22            image: kavachbank/api:latest
23            securityContext:
24              privileged: true
25              runAsUser: 0
```

IMPACT

A compromised or abandoned upstream can introduce vulnerable or malicious code.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

> Maintain an approved-components list and monitor upstream health.
>
> Estimated effort: low · target next release cycle

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-1104: Use of Unmaintained Third Party Components https://cwe.mitre.org/data/definitions/1104.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Vulnerable and Outdated Components https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/Vulnerable_Dependency_Management_Cheat_Sheet.html

Finding find_01M78W6HD8ZF1V2YYBRA15E4QB · fingerprint ckfp1:0e96cb749c726daec7f638742df172c7

CK-2026-058 **LOW** · **Open**

Action reference in job 'build' is not pinned to a commit SHA, so a moved tag changes what runs.

SEVERITY	RISK (L × I)	CONFIDENCE
Low	**4 × 2 = 8 (medium)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P4 · Planned**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
2.0 · CVSS:4.0/AV:L/AC:L/AT:P/PR:L/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L	1.9 · CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N	**CWE-829 Inclusion of Functionality from Untrusted Control Sphere**

OWASP TOP 10
A08:2021 Software and Data Integrity Failures

ASVS · CAPEC
V10.3.2 · CAPEC-175, CAPEC-201, CAPEC-251

LOCATION
`.github/workflows/ci.yml:10`

DETECTED BY
`codekavach-iac:iac.actions.unpinned-action`

DESCRIPTION

Action reference in job 'build' is not pinned to a commit SHA, so a moved tag changes what runs. The build or runtime executes code from a source outside the trust boundary, such as an untrusted pull request in a privileged CI workflow or an unpinned third-party action.

EVIDENCE

`.github/workflows/ci.yml · lines 10`

```
 7    build:
 8      runs-on: ubuntu-latest
 9      steps:
10        - uses: actions/checkout@v4
11          with:
12            ref: ${{ github.event.pull_request.head.sha }}
13        - name: Greet
```

IMPACT

An attacker can run code with the pipeline's secrets and write token, tamper with releases and pivot into the supply chain.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Separate untrusted builds from privileged jobs and review CI configuration as code.

Estimated effort: low · target next release cycle

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-829: Inclusion of Functionality from Untrusted Control Sphere `https://cwe.mitre.org/data/definitions/829.html`

- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Software and Data Integrity Failures https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/CI_CD_Security_Cheat_Sheet.html

Finding find_01M78W6HBRAQ4VRPWQAMYY5NBF · fingerprint ckfp1:b18c294516689c1f3f413f4f1f0b0532

CK-2026-059 **LOW** · **Open**

Action reference in job 'build' is not pinned to a commit SHA, so a moved tag changes what runs.

SEVERITY	RISK (L × I)	CONFIDENCE
Low	**4 × 2 = 8 (medium)**	**Medium**
STATUS	PRIORITY	OWASP RISK RATING
Open	**P4 · Planned**	**Medium (likelihood medium, impact medium)**
CVSS V4.0 (CVSS-B)	CVSS V3.1	CWE
2.0 · CVSS:4.0/AV:L/AC:L/AT:P/PR:L/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L	1.9 · CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N	**CWE-829 Inclusion of Functionality from Untrusted Control Sphere**
OWASP TOP 10	ASVS · CAPEC	LOCATION
A08:2021 Software and Data Integrity Failures	**V10.3.2 · CAPEC-175, CAPEC-201, CAPEC-251**	.github/workflows/ci.yml:15
DETECTED BY		
codekavach-iac:iac.actions.unpinned-action		

DESCRIPTION

Action reference in job 'build' is not pinned to a commit SHA, so a moved tag changes what runs. The build or runtime executes code from a source outside the trust boundary, such as an untrusted pull request in a privileged CI workflow or an unpinned third-party action.

EVIDENCE

.github/workflows/ci.yml · lines 15

```
12            ref: ${{ github.event.pull_request.head.sha }}
13        - name: Greet
14          run: echo "Building ${{ github.event.pull_request.title }}"
15        - uses: some-org/deploy-action@main
```

IMPACT

An attacker can run code with the pipeline's secrets and write token, tamper with releases and pivot into the supply chain.

LIKELIHOOD

OWASP likelihood medium; pattern match without a path

REMEDIATION

Fix now

Bind request data only to an explicit allow-list of fields (DTOs), never merge untrusted objects into prototypes or configuration, and load code and libraries only from fixed, trusted locations.

Prevent recurrence

Separate untrusted builds from privileged jobs and review CI configuration as code.

Estimated effort: low · target next release cycle

COMPLIANCE MAPPING

PCI DSS 4.0.1 6.2.3 | PCI DSS 4.0.1 6.3.1 | ISO/IEC 27001 2022 A.8.28 | ISO/IEC 27001 2022 A.8.29 | ISO/IEC 27001 2022 A.8.8 | NIST SSDF 1.1 PW.7.2 | NIST SSDF 1.1 RV.2.2 | RBI Cyber Security Framework 2016 Annex 1: ASLC | RBI IT Governance Master Direction 2023 Information security | SEBI CSCRF 2024 ID.RA | PCI DSS 4.0.1 6.3.2 | PCI DSS 4.0.1 6.3.3 | ISO/IEC 27001 2022 A.8.27 | NIST SSDF 1.1 PW.4.4 | RBI Cyber Security Framework 2016 Annex 1: Patch and vulnerability management | SEBI CSCRF 2024 PR.PS

Dashed: mapping derived from the weakness class; evidence against the clause, not an opinion of compliance.

REFERENCES

- CWE-829: Inclusion of Functionality from Untrusted Control Sphere https://cwe.mitre.org/data/definitions/829.html
- OWASP Mass Assignment Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
- OWASP Prototype Pollution Prevention Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/Prototype_Pollution_Prevention_Cheat_Sheet.html
- OWASP Top 10 2021 Software and Data Integrity Failures https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/
- OWASP Cheat Sheet Series https://cheatsheetseries.owasp.org/cheatsheets/CI_CD_Security_Cheat_Sheet.html

Finding find_01M78W6HBXW53P2T90GTG6HYM5 · fingerprint ckfp1:471879da9a1cbe4019240d54d895da30

7 Remediation roadmap

Actions are grouped by weakness class so that one change closes every instance, ordered by priority, then by the number of findings closed and the estimated effort.

PRIORITY	TIMELINE	WEAKNESS	ACTION	EFFORT	FINDINGS
P1	**Immediate** within 7 days	Use of Hard-coded Credentials	Revoke and rotate the exposed credential immediately, then load it at run time from a secret manager or environment.	Low	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014
P1	**Immediate** within 7 days	Dependency on Vulnerable Third-Party Component	Upgrade the component to a fixed version, or remove it if it is not needed.	Low	CK-2026-015
P1	**Immediate** within 7 days	Deserialisation of Untrusted Data	Use a safe loader (for example yaml.safe_load or JSON) that builds plain data only; never unpickle data from an untrusted source.	Low	CK-2026-013
P1	**Immediate** within 7 days	Execution with Unnecessary Privileges	Run the component as a non-root user, drop the privileged flag and grant only the capabilities it needs.	Low	CK-2026-002
P1	**Immediate** within 7 days	Inclusion of Functionality from Untrusted Control Sphere	Do not check out untrusted code in privileged workflows; pin third-party actions to a full commit SHA and reduce the token permissions.	Low	CK-2026-001
P1	**Immediate** within 7 days	OS Command Injection	Stop passing the command to a shell: call the program with an argument list (shell=False) and validate each argument against a strict allow-list.	Low	CK-2026-012
P1	**Immediate** within 7 days	SQL Injection	Use parameterised queries or prepared statements for every value that reaches the query; never format user data into SQL text.	Low	CK-2026-003
P2	**Short term** within 30 days	Dependency on Vulnerable Third-Party Component	Upgrade the component to a fixed version, or remove it if it is not needed.	Low	CK-2026-026, CK-2026-027, CK-2026-038, CK-2026-040, CK-2026-041, CK-2026-042
P2	**Short term** within 30 days	Execution with Unnecessary Privileges	Run the component as a non-root user, drop the privileged flag and grant only the capabilities it needs.	Low	CK-2026-018, CK-2026-019, CK-2026-021, CK-2026-022
P2	**Short term** within 30 days	Authorisation Bypass Through User-Controlled Key (IDOR)	Scope every lookup to the authenticated principal (for example WHERE owner_id = current_user) and return 404 for records the caller does not own.	Medium	CK-2026-032, CK-2026-036, CK-2026-037

PRIORITY	TIMELINE	WEAKNESS	ACTION	EFFORT	FINDINGS
P2	**Short term** within 30 days	Path Traversal	Resolve the final path and reject it unless it lies inside an allow-listed base directory; prefer opaque identifiers mapped server-side to file names.	Low	CK-2026-030, CK-2026-039
P2	**Short term** within 30 days	Use of Hard-coded Credentials	Revoke and rotate the exposed credential immediately, then load it at run time from a secret manager or environment.	Low	CK-2026-017, CK-2026-020
P2	**Short term** within 30 days	Exposure of Resource to Wrong Sphere	Restrict the exposure to the intended network or principals.	Low	CK-2026-025
P2	**Short term** within 30 days	Improper Certificate Validation	Re-enable certificate and hostname verification.	Low	CK-2026-028
P2	**Short term** within 30 days	Inadequate Encryption Strength	Use at least 2048-bit RSA or 256-bit elliptic curves and AES-128 or stronger.	Low	CK-2026-029
P2	**Short term** within 30 days	Incorrect Permission Assignment for Critical Resource	Tighten the permissions to the owning principal only.	Low	CK-2026-023
P2	**Short term** within 30 days	Missing Authorisation	Add the authentication and authorisation guard used elsewhere in the service to this route, defaulting to deny.	Low	CK-2026-033
P2	**Short term** within 30 days	OS Command Injection	Stop passing the command to a shell: call the program with an argument list (shell=False) and validate each argument against a strict allow-list.	Low	CK-2026-016
P2	**Short term** within 30 days	Predictable Initialisation Vector	Generate a fresh random IV (or nonce) for every encryption with a CSPRNG and store it alongside the ciphertext.	Low	CK-2026-035
P2	**Short term** within 30 days	Improper Access Control	Add the missing access check, denying by default.	Medium	CK-2026-024
P2	**Short term** within 30 days	Server-Side Request Forgery	Validate the destination against an allow-list of hosts and schemes and block private, loopback and link-local address ranges after DNS resolution.	Medium	CK-2026-031

PRIORITY	TIMELINE	WEAKNESS	ACTION	EFFORT	FINDINGS
P2	**Short term** within 30 days	Use of a Broken or Risky Cryptographic Algorithm	Hash passwords with a slow, salted, memory-hard function such as Argon2id, scrypt or bcrypt, and migrate existing hashes on next login.	Medium	CK-2026-034
P3	**Medium term** within 90 days	Execution with Unnecessary Privileges	Run the component as a non-root user, drop the privileged flag and grant only the capabilities it needs.	Low	CK-2026-043, CK-2026-044, CK-2026-047
P3	**Medium term** within 90 days	Cross-site Scripting	Encode output for its HTML context (or use a template engine with auto-escaping) and never send raw request data with res.send or equivalent.	Low	CK-2026-051, CK-2026-054
P3	**Medium term** within 90 days	Download of Code Without Integrity Check	Verify a pinned checksum or signature before executing downloaded artefacts.	Low	CK-2026-045, CK-2026-052
P3	**Medium term** within 90 days	Active Debug Code	Disable debug mode and remove debug endpoints from production builds.	Low	CK-2026-053
P3	**Medium term** within 90 days	Dependency on Vulnerable Third-Party Component	Upgrade the component to a fixed version, or remove it if it is not needed.	Low	CK-2026-050
P3	**Medium term** within 90 days	Exposure of Resource to Wrong Sphere	Restrict the exposure to the intended network or principals.	Low	CK-2026-046
P3	**Medium term** within 90 days	Permissive Cross-domain Policy	Restrict allowed origins to a known list.	Low	CK-2026-049
P3	**Medium term** within 90 days	Missing Encryption of Sensitive Data	Encrypt the data in transit with TLS and at rest with a managed key.	Medium	CK-2026-048
P4	**Planned** next release cycle	Inclusion of Functionality from Untrusted Control Sphere	Do not check out untrusted code in privileged workflows; pin third-party actions to a full commit SHA and reduce the token permissions.	Low	CK-2026-058, CK-2026-059
P4	**Planned** next release cycle	Use of Unmaintained Third-Party Components	Pin the component to a reviewed version or digest and replace unmaintained components.	Low	CK-2026-055, CK-2026-057
P4	**Planned** next release cycle	Allocation of Resources Without Limits	Set explicit limits (request size, rate, timeouts, container resources).	Low	CK-2026-056

8 Privacy attestation

Ledger verified Zero-leak passed

This attestation states exactly what left the client environment during the review. It is computed from the hash-chained egress ledger, which records every request to a language model before it is sent.

Privacy level (default)	L3
Provider and model	agentrouter / gpt-5.6-sol (remote)
Ledger entries	56; blocked: 2; completed: 23; failed: 4; sent: 27
Payloads sent / blocked	27 / 2
Tokens (prompt / completion)	92,314 / 187,292
Placeholders by type	secret:razorpay_key_id: 1 secret:razorpay_key_secret: 1
Code slices prepared	16
Files with disclosed code	9
Functions with disclosed code	13
Lines disclosed	86
Lines prepared (incl. placeholders)	119
Tokens per payload set (estimated)	1347
Share of the repository disclosed (%)	9.19
Call edges summarised	4
Context expansions	0
Slices by enclosing function	14
Slices by hotspot window	2
Ledger head hash	`9f10f34c7def11e378c61d4ec5f22ea9b04d4233827870dfda1558f6c9125962`
Chain verification	verified: every entry links to its predecessor and its hash recomputes

Zero-leak check	31 listed terms searched in every ledger payload: no occurrence
Retention	kept until the vault is destroyed

What this attestation does not cover. The zero-leak check is verbatim: it looks for the listed terms as written and does not detect a term that was paraphrased, split or encoded. The structure of the code, its control flow, the libraries it uses and the technology stack are still disclosed to the model whatever the privacy level. Structural leakage, meaning what an observer could infer from that structure, is measured separately by the evaluation harness and is not part of this check.

9 Appendices

A. Tools, engines and versions

TOOL	VERSION	ROLE	MODE
CodeKavach	`0.1.0.dev0`	Orchestration, rules, taint analysis, privacy layer, reporting	local
codekavach-iac	1	Detection engine	local
codekavach-taint	n/a	Detection engine	local
codekavach-secrets	1	Detection engine	local
codekavach.rules	1	Detection engine	local
codekavach-sca	n/a	Detection engine	local
codekavach-rules	`default@1.0.0`	Detection engine	local
agentrouter / gpt-5.6-sol	n/a	Model-assisted triage (advisory)	remote API

B. Coverage

Files analysed	29
Lines analysed	936
Findings in YAML	20
Findings in Python	15
Findings in Unknown	8
Findings in JavaScript	7
Findings in Dockerfile	5
Findings in Terraform	4
Candidates	59 (reviewed by model: 12)
Not reviewed: egress_blocked	2
Not reviewed: llm_output_invalid	1
Not reviewed: llm_request_failed	1

Not reviewed: privacy_pseudonymise_failed	6
Not reviewed: privacy_slice_failed	37

C. Files reviewed

#	PATH
1	.codekavachignore
2	.github/workflows/ci.yml
3	README.md
4	deploy/Dockerfile
5	deploy/docker-compose.yml
6	deploy/k8s/api.yaml
7	fixtures/seed/customers.json
8	infra/main.tf
9	services/api/accounts.py
10	services/api/config.py
11	services/api/db.py
12	services/api/fee_schedule.py
13	services/api/fraud_rules.py
14	services/api/handlers.py
15	services/api/interest_engine.py
16	services/api/loan_scoring.py
17	services/api/reports.py
18	services/api/requirements.txt
19	services/api/security.py
20	services/api/serialisation.py
21	services/api/settings.yaml
22	services/api/webhooks.py

#	PATH
23	services/web/config.js
24	services/web/exporter.js
25	services/web/package.json
26	services/web/payments.js
27	services/web/renderer.js
28	services/web/routes.js
29	services/web/session.js

D. Compliance annex

Each row lists the findings that are evidence against a control. This is not an opinion of compliance; controls without findings were not necessarily tested.

FRAMEWORK	CONTROL	TITLE	FINDINGS
CERT-In 2022	Directions 2022 (iv)	Logs of ICT systems are maintained securely for a rolling period of 180 days	CK-2026-025, CK-2026-046
ISO/IEC 27001 2022	A.5.15	Access control	CK-2026-023, CK-2026-024, CK-2026-030, CK-2026-032, CK-2026-033, CK-2026-036, CK-2026-037, CK-2026-039
ISO/IEC 27001 2022	A.5.17	Authentication information	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020
ISO/IEC 27001 2022	A.5.34	Privacy and protection of PII	CK-2026-025, CK-2026-046
ISO/IEC 27001 2022	A.8.11	Data masking	CK-2026-025, CK-2026-046
ISO/IEC 27001 2022	A.8.12	Data leakage prevention	CK-2026-025, CK-2026-046
ISO/IEC 27001 2022	A.8.15	Logging	CK-2026-025, CK-2026-046
ISO/IEC 27001 2022	A.8.20	Networks security	CK-2026-031
ISO/IEC 27001 2022	A.8.24	Use of cryptography	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020, CK-2026-028, CK-2026-029, CK-2026-034, CK-2026-035, CK-2026-048
ISO/IEC 27001 2022	A.8.26	Application security requirements	CK-2026-003, CK-2026-012, CK-2026-013, CK-2026-016, CK-2026-030, CK-2026-031, CK-2026-039, CK-2026-051, CK-2026-054
ISO/IEC 27001 2022	A.8.27	Secure system architecture and engineering principles	CK-2026-001, CK-2026-013, CK-2026-015, CK-2026-026, CK-2026-027, CK-2026-038, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-045, CK-2026-050, CK-2026-052, CK-2026-055, CK-2026-057, CK-2026-058, CK-2026-059

FRAMEWORK	CONTROL	TITLE	FINDINGS
ISO/IEC 27001 2022	A.8.28	Secure coding	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059
ISO/IEC 27001 2022	A.8.29	Security testing in development and acceptance	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059
ISO/IEC 27001 2022	A.8.3	Information access restriction	CK-2026-023, CK-2026-024, CK-2026-030, CK-2026-032, CK-2026-033, CK-2026-036, CK-2026-037, CK-2026-039
ISO/IEC 27001 2022	A.8.4	Access to source code	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020
ISO/IEC 27001 2022	A.8.6	Capacity management	CK-2026-056
ISO/IEC 27001 2022	A.8.8	Management of technical vulnerabilities	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059
ISO/IEC 27001 2022	A.8.9	Configuration management	CK-2026-002, CK-2026-018, CK-2026-019, CK-2026-021, CK-2026-022, CK-2026-043, CK-2026-044, CK-2026-047, CK-2026-049, CK-2026-053
NIST SSDF 1.1	PS.1.1	Store all forms of code based on the principle of least privilege	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020

FRAMEWORK	CONTROL	TITLE	FINDINGS
NIST SSDF 1.1	PW.4.4	Verify that acquired commercial, open-source and other third-party software components comply with requirements	CK-2026-001, CK-2026-013, CK-2026-015, CK-2026-026, CK-2026-027, CK-2026-038, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-045, CK-2026-050, CK-2026-052, CK-2026-055, CK-2026-057, CK-2026-058, CK-2026-059
NIST SSDF 1.1	PW.5.1	Follow all secure coding practices appropriate to the languages and environment	CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-016, CK-2026-017, CK-2026-020, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-039, CK-2026-046, CK-2026-048, CK-2026-051, CK-2026-054, CK-2026-056
NIST SSDF 1.1	PW.7.2	Review and/or analyze human-readable code to identify vulnerabilities	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059
NIST SSDF 1.1	PW.9.1	Define a secure baseline by determining how to configure each setting	CK-2026-002, CK-2026-018, CK-2026-019, CK-2026-021, CK-2026-022, CK-2026-043, CK-2026-044, CK-2026-047, CK-2026-049, CK-2026-053
NIST SSDF 1.1	RV.2.2	Plan and implement risk responses for vulnerabilities	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059
OWASP Top 10	A01:2021	Broken Access Control	CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-027, CK-2026-030, CK-2026-032, CK-2026-033, CK-2026-036, CK-2026-037, CK-2026-039, CK-2026-046, CK-2026-050
OWASP Top 10	A02:2021	Cryptographic Failures	CK-2026-006, CK-2026-029, CK-2026-034, CK-2026-035
OWASP Top 10	A03:2021	Injection	CK-2026-003, CK-2026-012, CK-2026-015, CK-2026-016, CK-2026-038, CK-2026-040, CK-2026-050, CK-2026-051, CK-2026-054
OWASP Top 10	A04:2021	Insecure Design	CK-2026-026, CK-2026-027, CK-2026-048, CK-2026-056
OWASP Top 10	A05:2021	Security Misconfiguration	CK-2026-002, CK-2026-018, CK-2026-019, CK-2026-021, CK-2026-022, CK-2026-043, CK-2026-044, CK-2026-047, CK-2026-049, CK-2026-053

FRAMEWORK	CONTROL	TITLE	FINDINGS
OWASP Top 10	A06:2021	Vulnerable and Outdated Components	CK-2026-015, CK-2026-026, CK-2026-027, CK-2026-038, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-050, CK-2026-055, CK-2026-057
OWASP Top 10	A07:2021	Identification and Authentication Failures	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020, CK-2026-028, CK-2026-042
OWASP Top 10	A08:2021	Software and Data Integrity Failures	CK-2026-001, CK-2026-013, CK-2026-040, CK-2026-045, CK-2026-052, CK-2026-058, CK-2026-059
OWASP Top 10	A10:2021	Server-Side Request Forgery (SSRF)	CK-2026-031, CK-2026-041
PCI DSS 4.0.1	1.3.2	Outbound traffic from the CDE is restricted	CK-2026-031
PCI DSS 4.0.1	10.2.1	Audit logs are enabled and active for all system components	CK-2026-025, CK-2026-046
PCI DSS 4.0.1	10.3.2	Audit log files are protected to prevent modification	CK-2026-025, CK-2026-046
PCI DSS 4.0.1	2.2.1	Configuration standards are developed, implemented and maintained	CK-2026-002, CK-2026-018, CK-2026-019, CK-2026-021, CK-2026-022, CK-2026-043, CK-2026-044, CK-2026-047, CK-2026-049, CK-2026-053
PCI DSS 4.0.1	3.5.1	PAN is rendered unreadable anywhere it is stored	CK-2026-025, CK-2026-046
PCI DSS 4.0.1	3.6.1	Procedures protect cryptographic keys against disclosure and misuse	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020, CK-2026-028, CK-2026-029, CK-2026-034, CK-2026-035, CK-2026-048
PCI DSS 4.0.1	4.2.1	Strong cryptography protects data during transmission over open, public networks	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020, CK-2026-028, CK-2026-029, CK-2026-034, CK-2026-035, CK-2026-048
PCI DSS 4.0.1	6.2.3	Bespoke and custom software is reviewed prior to release to identify and correct coding vulnerabilities	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059

FRAMEWORK	CONTROL	TITLE	FINDINGS
PCI DSS 4.0.1	6.2.4	Software engineering techniques prevent or mitigate common software attacks (injection, data structure, cryptography, business logic, access control, XSS, CSRF)	CK-2026-003, CK-2026-012, CK-2026-013, CK-2026-016, CK-2026-030, CK-2026-031, CK-2026-039, CK-2026-051, CK-2026-054, CK-2026-056
PCI DSS 4.0.1	6.3.1	Security vulnerabilities are identified and managed	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059
PCI DSS 4.0.1	6.3.2	An inventory of bespoke, custom and third-party software components is maintained	CK-2026-001, CK-2026-013, CK-2026-015, CK-2026-026, CK-2026-027, CK-2026-038, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-045, CK-2026-050, CK-2026-052, CK-2026-055, CK-2026-057, CK-2026-058, CK-2026-059
PCI DSS 4.0.1	6.3.3	System components are protected from known vulnerabilities by installing patches	CK-2026-001, CK-2026-013, CK-2026-015, CK-2026-026, CK-2026-027, CK-2026-038, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-045, CK-2026-050, CK-2026-052, CK-2026-055, CK-2026-057, CK-2026-058, CK-2026-059
PCI DSS 4.0.1	7.2.1	An access control model is defined and includes granting access appropriately	CK-2026-023, CK-2026-024, CK-2026-030, CK-2026-032, CK-2026-033, CK-2026-036, CK-2026-037, CK-2026-039
PCI DSS 4.0.1	7.2.2	Access is assigned based on job classification and least privilege	CK-2026-023, CK-2026-024, CK-2026-030, CK-2026-032, CK-2026-033, CK-2026-036, CK-2026-037, CK-2026-039
PCI DSS 4.0.1	8.6.2	Passwords for application and system accounts are not hard coded in scripts, configuration files or source code	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020
RBI Cyber Security Framework 2016	Annex 1: ASLC	Application Security Life Cycle (ASLC) (Annex 1 section; cited at section level)	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059

FRAMEWORK	CONTROL	TITLE	FINDINGS
RBI Cyber Security Framework 2016	Annex 1: Audit logs	Maintenance, Monitoring, and Analysis of Audit Logs (Annex 1 section; cited at section level)	CK-2026-025, CK-2026-046
RBI Cyber Security Framework 2016	Annex 1: Data leak prevention	Data Leak prevention strategy (Annex 1 section; cited at section level)	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020, CK-2026-025, CK-2026-028, CK-2026-029, CK-2026-034, CK-2026-035, CK-2026-046, CK-2026-048
RBI Cyber Security Framework 2016	Annex 1: Network security	Network Management and Security (Annex 1 section; cited at section level)	CK-2026-031
RBI Cyber Security Framework 2016	Annex 1: Patch and vulnerability management	Patch/Vulnerability and Change Management (Annex 1 section; cited at section level)	CK-2026-001, CK-2026-013, CK-2026-015, CK-2026-026, CK-2026-027, CK-2026-038, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-045, CK-2026-050, CK-2026-052, CK-2026-055, CK-2026-057, CK-2026-058, CK-2026-059
RBI Cyber Security Framework 2016	Annex 1: Secure configuration	Secure Configuration (Annex 1 section; cited at section level)	CK-2026-002, CK-2026-018, CK-2026-019, CK-2026-021, CK-2026-022, CK-2026-043, CK-2026-044, CK-2026-047, CK-2026-049, CK-2026-053
RBI Cyber Security Framework 2016	Annex 1: User access control	User Access Control / Management (Annex 1 section; cited at section level)	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020, CK-2026-023, CK-2026-024, CK-2026-030, CK-2026-032, CK-2026-033, CK-2026-036, CK-2026-037, CK-2026-039
RBI IT Governance Master Direction 2023	Information security	Application security controls in the IT governance direction (framework level)	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059
SEBI CSCRF 2024	DE.CM	Detect: continuous monitoring (category level)	CK-2026-025, CK-2026-046

FRAMEWORK	CONTROL	TITLE	FINDINGS
SEBI CSCRF 2024	ID.RA	Identify: risk assessment, including vulnerability assessment (category level)	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-012, CK-2026-013, CK-2026-014, CK-2026-015, CK-2026-016, CK-2026-017, CK-2026-018, CK-2026-019, CK-2026-020, CK-2026-021, CK-2026-022, CK-2026-023, CK-2026-024, CK-2026-025, CK-2026-026, CK-2026-027, CK-2026-028, CK-2026-029, CK-2026-030, CK-2026-031, CK-2026-032, CK-2026-033, CK-2026-034, CK-2026-035, CK-2026-036, CK-2026-037, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-046, CK-2026-047, CK-2026-048, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059
SEBI CSCRF 2024	PR.AA	Protect: identity management, authentication and access control (category level)	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020, CK-2026-023, CK-2026-024, CK-2026-030, CK-2026-032, CK-2026-033, CK-2026-036, CK-2026-037, CK-2026-039
SEBI CSCRF 2024	PR.DS	Protect: data security (category level)	CK-2026-004, CK-2026-005, CK-2026-006, CK-2026-007, CK-2026-008, CK-2026-009, CK-2026-010, CK-2026-011, CK-2026-014, CK-2026-017, CK-2026-020, CK-2026-025, CK-2026-028, CK-2026-029, CK-2026-034, CK-2026-035, CK-2026-046, CK-2026-048
SEBI CSCRF 2024	PR.PS	Protect: platform and application security (category level)	CK-2026-001, CK-2026-002, CK-2026-003, CK-2026-012, CK-2026-013, CK-2026-015, CK-2026-016, CK-2026-018, CK-2026-019, CK-2026-021, CK-2026-022, CK-2026-026, CK-2026-027, CK-2026-030, CK-2026-031, CK-2026-038, CK-2026-039, CK-2026-040, CK-2026-041, CK-2026-042, CK-2026-043, CK-2026-044, CK-2026-045, CK-2026-047, CK-2026-049, CK-2026-050, CK-2026-051, CK-2026-052, CK-2026-053, CK-2026-054, CK-2026-055, CK-2026-056, CK-2026-057, CK-2026-058, CK-2026-059

E. Limitations

ID	KIND	STATEMENT
L-1	technique	Static analysis only: the application was not executed, so runtime configuration, deployed infrastructure and third-party services were not tested.
L-2	coverage	Rule and taint coverage is limited to the languages and frameworks the rule packs model; business-logic flaws that do not match a rule may be missed.
L-3	model	Model-assisted assessments are probabilistic and advisory. They lower or raise confidence but never remove a deterministic finding from this report.
L-4	dependencies	Known-vulnerable third-party components are reported only where an engine for dependency analysis was enabled for the run.
L-5	coverage	Some candidates were not reviewed by the model: egress_blocked (2), llm_output_invalid (1), llm_request_failed (1), privacy_pseudonymise_failed (6), privacy_slice_failed (37). They are still reported with their deterministic rating.